

커넥티드카 원격 차량 기능 제어 Item TARA

ISO/SAE 21434:2021 및 국내 TARA 매뉴얼 적용 정리본

분석 범위: generic/reference Connected-Car Remote Vehicle Function Control Item

문서 상태와 적용 범위

본 문서는 특정 OEM 양산차의 적합성 평가 문서가 아니라, 공개된 connected-car 원격명령 기능을 바탕으로 구성한 generic/reference Item 을 대상으로 수행한 TARA 결과를 정리한 문서다. ISO/SAE 21434 Clause 15 의 TARA 는 자산 식별부터 위험 처리 결정까지이며, 본 문서는 WP-15-01 부터 WP-15-08 까지의 결과를 모두 포함한다. 이어서 국내 매뉴얼의 작성 순서에 맞춰 Cybersecurity Goal, Cybersecurity Claim 및 CAL 평가까지 정리했다.

제품 내부의 실제 ECU 배치, backend authorization, key storage, diagnostic access restriction 등 공개자료만으로 확인할 수 없는 사항은 특정 OEM 사실로 기술하지 않았다. 필요한 경우 reference architecture 의 가정으로 분리했다. 따라서 본 문서의 수치와 등급은 reference Item 에 대한 일관된 분석값이며, 특정 차종의 양산 HARA 또는 compliance-grade TARA 결과로 해석하면 안 된다.

표 1 분석 결과 요약

구분	결과
Item Function	7 개
Asset	13 개
Damage Scenario	17 개
Threat Scenario	43 개
Attack Path	16 개
Impact Rating	68/68 평가
Attack Feasibility	16/16 평가
Risk Value	43/43 산정
Risk Treatment	위험 감소 42, 위험 유지 1
Cybersecurity Goal	10 개
Cybersecurity Claim	1 개

1. 적용 기준과 분석 원칙

표 구성과 작성 순서는 「ISO/SAE 21434 기반 사이버보안 위협 분석 및 위험 평가 매뉴얼」의 아이템 정의, 자산 식별, 위협 시나리오 식별, 영향 등급, 공격 경로 분석, 공격 실현 가능성, 위험 값, 위험 처리, CAL, 사이버보안 목표 및 주장 순서를 준용했다. 요구사항 번호와 Work Product 명칭은 ISO/SAE 21434:2021 을 기준으로 사용했다.

표 2 주요 Work Product 흐름

Work Product	명칭	본 문서의 내용
WP-09-01	Item Definition	Item 경계, 기능, 예비 아키텍처, 운용환경
WP-15-01	Damage Scenarios	피해 시나리오
WP-15-02	Assets with Cybersecurity Properties	사이버보안 속성을 가진 자산

Work Product	명칭	본 문서의 내용
WP-15-03	Threat Scenarios	위협 시나리오
WP-15-04	Impact Ratings	S/F/O/P 영향 등급
WP-15-05	Attack Paths	공격 경로
WP-15-06	Attack Feasibility Ratings	공격 실현 가능성
WP-15-07	Risk Values	위험 값 1~5
WP-15-08	Risk Treatment Decisions	위험 회피/감소/공유/유지
WP-09-03	Cybersecurity Goals	위험 감소 대상의 상위 보안 목표
WP-09-04	Cybersecurity Claims	위험 공유 또는 가정 기반 위험 유지의 근거

1.1 분석 가정

표 3 Reference Item 분석 가정

ID	가정
A-01	본 분석의 Item 은 특정 OEM 또는 특정 차종의 양산 아키텍처가 아니라 공개된 connected-car client/SDK 에서 관찰된 원격명령 기능을 바탕으로 구성한 generic/reference Item 이다.
A-02	공개 client 코드에서 확인할 수 없는 backend-side authorization, rate limiting, MFA, key protection 등의 존재 또는 부재를 사실로 단정하지 않는다.
A-03	실제 ECU 배치, CAN/Ethernet topology, gateway 구성은 공개 근거가 없는 경우 논리적 컴포넌트로만 표현한다.
A-04	특정 OEM 에서 관찰된 보안통제가 다른 OEM 또는 본 reference Item 전체에 공통으로 존재한다고 가정하지 않는다.
A-05	속도, 기어, 점화, 충전 상태 등의 state interlock 은 해당 구현에서 실제로 사용하는 조건일 때 적용된다.
A-06	원격명령 command 가 공개 client/SDK 에 존재한다는 사실은 해당 명령이 모든 차종과 지역에서 동일하게 서비스된다는 뜻이 아니다.
A-07	Cloud 또는 client 관찰 결과만으로 차량 내부의 구체적인 ECU, 키 저장 방식, 메시지 보호 방식까지 역추론하지 않는다.

2. 아이템 정의(Item Definition)

분석 Item 은 Connected-Car Remote Vehicle Function Control Item 으로 정의한다. 차량 외부에서 요청된 원격명령을 차량 측 E/E 시스템이 수신하고 처리한 뒤, 관련 차량 기능으로 전달하여 실행 또는 거부하고 처리 결과를 제공하는 논리적 E/E 컴포넌트 집합이다. Mobile App, Backend, 인터넷, 셀룰러 인프라는 분석에서 제외하는 것이 아니라 Operational Environment 로 분리한다.

2.1 운용 환경과 Item 경계

표 4 시스템 운용 환경

ID	영문명	요소	Item 과의 상호작용	구분
OE-01	Authorized / Requesting User	정당한 사용자	모바일 앱 또는 API client 를 통해 원격 차량 기능을 요청한다.	외부

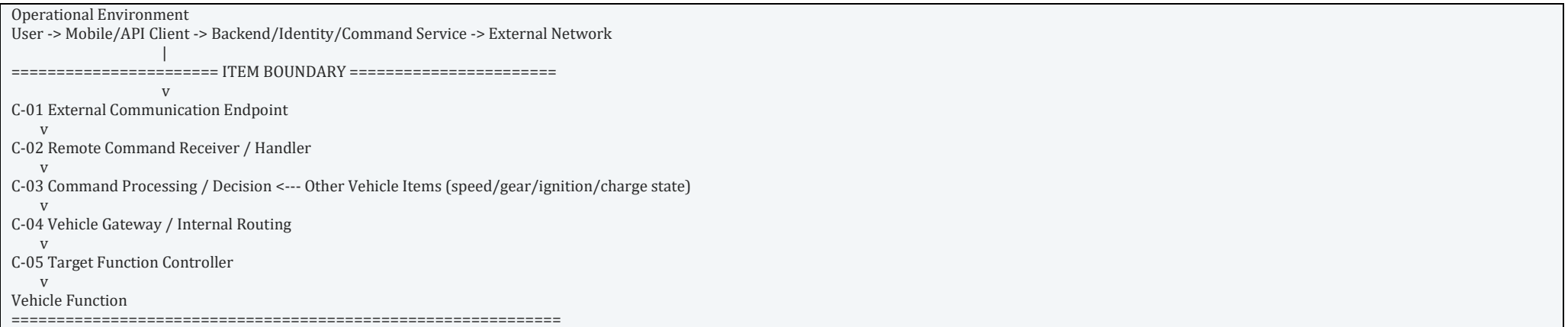
ID	영문명	요소	Item 과의 상호작용	구분
OE-02	Mobile App / API Client	모바일 앱 / API Client	사용자 입력과 인증 문맥을 바탕으로 원격명령 요청을 생성한다.	외부
OE-03	Backend / Command Service	Backend / Command Service	원격명령 요청을 처리하고 차량 측 통신 경로로 전달한다.	외부
OE-04	Identity / Credential Service	신원, 자격정보 서비스	사용자 또는 서비스의 인증정보와 권한 문맥을 제공하거나 관리한다.	외부
OE-05	External Network Infrastructure	인터넷, 셀룰러, 메시징 인프라	Backend 와 차량 사이의 원격 통신을 제공한다.	외부
OE-06	Other Vehicle Items	다른 차량 Item	속도, 기어, 점화, 충전 상태 등 원격명령 판단에 필요한 차량 상태를 제공할 수 있다.	차량 내 외부 Item
OE-07	Diagnostic / Service Environment	진단, 정비 환경	진단, 정비, 재프로그래밍 과정에서 Item 과 상호작용할 수 있다.	외부
OE-08	External Charging Infrastructure	외부 충전 인프라	충전 기능과 관련해 차량과 상호작용할 수 있다.	외부

기준: ISO/SAE 21434:2021 [RQ-09-02], 국내 TARA 매뉴얼 2.1 Item Definition.

표 5 Item 내부 논리 컴포넌트

ID	Logical Component	한글명	역할
C-01	Vehicle External Communication Endpoint	차량 외부 통신 종단점	외부 원격명령을 차량 E/E 영역에서 처음 수신하는 논리적 종단점
C-02	Remote Command Receiver / Handler	원격명령 수신, 처리부	원격명령의 수신, 형식 확인, 해석 및 후속 처리 연결
C-03	Command Processing / Decision	명령 처리, 수락 판단부	명령 수락 여부, 권한 문맥, freshness, 차량 상태 조건 등을 판단하는 논리적 기능
C-04	Vehicle Gateway / Internal Routing	차량 Gateway / 내부 라우팅	수락된 명령을 허용된 차량 내부 경로와 대상 기능으로 전달
C-05	Target Function Controller	대상 기능 제어기	원격명령 대상 차량 기능을 실제로 수행하는 논리적 제어기

그림 1 Item 경계 및 예비 아키텍처



2.2 아이템 기능

표 6 아이템 기능

아이템 기능 ID	기능(영문)	기능	설명
IF-01	Vehicle Access Control	차량 접근 제어	원격 요청에 따라 차량 도어의 잠금 또는 잠금 해제 상태를 변경한다.
IF-02	Propulsion and Mobility Authorization	원동기 및 주행 권한 제어	원격 요청에 따라 차량의 원동기 작동, 정지 또는 원격 주행 가능 상태를 제어한다.
IF-03	Closure and Mechanical Access Control	개구부 및 기계적 접근 제어	원격 요청에 따라 창문, 선루프, 트렁크, 프렁크, 적재함 덮개, 충전구 등 전동식 개구부의 상태를 변경한다.
IF-04	Cabin Thermal and Comfort Control	실내 열, 공조 및 편의 기능 제어	원격 요청에 따라 차량 실내 공조, 보조 난방, 유리 열선, 좌석 및 스티어링 휠 난방 등의 열, 편의 기능을 제어한다.
IF-05	Charging and HV Battery Energy Management	충전 및 고전압 배터리 에너지 관리	원격 요청에 따라 충전 시작, 정지, 충전 전류, 한도 및 고전압 배터리 컨디셔닝 상태를 제어한다.
IF-06	Audible/Visual Signaling and Vehicle Finding	가청, 시각 신호 및 차량 탐색	원격 요청에 따라 경적, 등화 및 비상등 등의 신호를 작동해 차량 상태 표시 또는 차량 위치 식별을 지원한다.
IF-07	Vehicle Security and Operational Mode Control	차량 보안 및 운용 모드 제어	원격 요청에 따라 차량의 보안 또는 제한 운용 모드를 활성화하거나 비활성화한다.

2.3 사이버보안 관련성

표 7 아이템 기능의 사이버보안 관련성

아이템 기능 ID	기능	설명	사이버보안 관련성
IF-01	차량 접근 제어	원격 요청에 따라 차량 도어의 잠금 또는 잠금 해제 상태를 변경한다.	0
IF-02	원동기 및 주행 권한 제어	원격 요청에 따라 차량의 원동기 작동, 정지 또는 원격 주행 가능 상태를 제어한다.	0
IF-03	개구부 및 기계적 접근 제어	원격 요청에 따라 창문, 선루프, 트렁크, 프렁크, 적재함 덮개, 충전구 등 전동식 개구부의 상태를 변경한다.	0
IF-04	실내 열, 공조 및 편의 기능 제어	원격 요청에 따라 차량 실내 공조, 보조 난방, 유리 열선, 좌석 및 스티어링 휠 난방 등의 열, 편의 기능을 제어한다.	0
IF-05	충전 및 고전압 배터리 에너지 관리	원격 요청에 따라 충전 시작, 정지, 충전 전류, 한도 및 고전압 배터리 컨디셔닝 상태를 제어한다.	0
IF-06	가청, 시각 신호 및 차량 탐색	원격 요청에 따라 경적, 등화 및 비상등 등의 신호를 작동해 차량 상태 표시 또는 차량 위치 식별을 지원한다.	0
IF-07	차량 보안 및 운용 모드 제어	원격 요청에 따라 차량의 보안 또는 제한 운용 모드를 활성화하거나 비활성화한다.	0

본 Item 은 차량 E/E 기능을 네트워크 기반으로 원격 제어하며, 원동기, 주행, 충전, 접근제어 등 차량 기능과 직접 연결된다. 따라서 Item Function 7 개를 모두 TARA 대상으로 유지한다.

3. TARA

3.1 자산 식별(Asset Identification)

표 8 자산 식별 단계 목표

구분	내용
ISO/SAE 21434	15.3 Asset identification
목적	자산, 사이버보안 속성 및 피해 시나리오를 식별한다.
요구사항 및 권고사항	[RQ-15-01] 피해 시나리오를 식별한다. [RQ-15-02] 피해 시나리오로 이어지는 사이버보안 속성을 가진 자산을 식별한다.
작업 산출물	[WP-15-01] Damage scenarios [WP-15-02] Assets with cybersecurity properties

표 9 자산 및 피해 시나리오 도출

자산 ID	자산	기밀성	무결성	가용성	연결 피해 시나리오
AS-01	차량 접근제어 원격명령 데이터 및 제어정보	-	0	0	DS-01, DS-02
AS-02	원동기, 주행 권한 관련 원격명령 데이터 및 제어정보	-	0	0	DS-03, DS-04
AS-03	개구부, 기계 구동 원격명령 데이터 및 제어정보	-	0	0	DS-05, DS-06, DS-07
AS-04	열, 공조, 편의 원격명령 데이터 및 제어정보	-	0	0	DS-08, DS-09
AS-05	충전, 고전압 배터리 관리 원격명령 데이터 및 제어정보	-	0	0	DS-10, DS-11
AS-06	가청, 시각 신호 및 차량찾기 원격명령 데이터	-	0	0	DS-12, DS-13
AS-07	차량 보안, 운용모드 원격명령 데이터 및 모드 제어정보	-	0	0	DS-14, DS-15
AS-08	명령의 대상 차량, 대상 기능 결합 및 내부 라우팅 정보	-	0	0	DS-01~DS-15 중 해당 기능 피해
AS-09	차량 측 원격명령 수신, 해석, 수락, 거부 처리 상태 및 로직	-	0	0	DS-01~DS-15 중 해당 기능 피해
AS-10	원격명령 실행 결과, 상태 및 거래 메타데이터	0	0	0	DS-16, DS-17
AS-11	차량 내부에서 수락된 명령을 대상 제어기로 전달하는 통신 데이터	-	0	0	DS-01~DS-15 중 해당 기능 피해
AS-12	원격명령 대상 차량 기능을 구현하는 제어 SW/FW	-	0	0	DS-01~DS-15 중 해당 기능 피해
AS-13	원격명령 처리 판단에 사용되는 차량 상태, 운용조건 입력 데이터	-	0	0	DS-01~DS-15 중 상태 조건에 의존하는 피해

표 10 피해 시나리오

피해 시나리오 ID	피해 시나리오
DS-01	차량의 잠금 상태가 정당한 사용자의 의도와 다르게 변경되어 차량 또는 차량 내 물품에 대한 비인가 물리적 접근이 가능해진다.
DS-02	정당한 사용자가 필요한 시점에 차량의 잠금/해제 상태를 원격으로 변경하지 못해 정상적인 차량 접근 또는 차량 보호 기능을 이용하지 못한다.
DS-03	원동기 작동 또는 원격 주행 가능 상태가 의도하지 않게 활성화되어 차량이 사용자의 의도와 다른 동작 가능 상태가 되고, 조건에 따라 차량 또는 도로 사용자에게 위해가 발생할 수 있다.

피해 시나리오 ID	피해 시나리오
DS-04	원동기 또는 주행 관련 상태가 의도하지 않게 중지, 비활성화되거나 필요한 기능을 사용할 수 없어 차량 이동성이 상실되며, 운행 조건에 따라 도로 사용자에게 위해가 발생할 수 있다.
DS-05	창문, 전루프, 트렁크, 프렁크, 충전구 등의 개구부가 의도하지 않게 열리거나 열린 상태가 되어 차량 내부 또는 적재물의 보호가 저하된다.
DS-06	전동 개구부가 의도하지 않은 시점에 닫히거나 움직여 주변 사람 또는 물체와 충돌, 끼임이 발생할 수 있다.
DS-07	정당한 사용자가 필요한 개구부를 원격으로 조작하지 못하여 차량을 정상적으로 사용하거나 보호하지 못한다.
DS-08	공조, 보조난방, 유리열선, 좌석, 스티어링 난방 등이 의도하지 않게 작동하거나 설정되어 불필요한 에너지 소비 또는 의도하지 않은 실내 열환경이 발생한다.
DS-09	필요한 원격 열, 공조 기능을 사용할 수 없어 사전 공조 또는 관련 편의 기능을 정상적으로 이용하지 못한다.
DS-10	충전이 의도하지 않게 중지되거나 충전 한도가 감소하거나 충전 제어가 불가능하여 필요한 시점에 충분한 배터리 충전량을 확보하지 못하고 차량의 이용 가능성이 저하된다.
DS-11	충전이 의도하지 않게 시작되거나 충전 전류, 한도 등이 변경되어 사용자가 의도하지 않은 에너지 소비 또는 비용이 발생한다.
DS-12	경적, 등화, 비상등 등의 외부 신호가 의도하지 않게 작동하여 차량 주변 사람 또는 다른 도로 사용자에게 잘못된 신호를 제공하거나 주의를 분산시킨다.
DS-13	차량 찾기 또는 원격 신호 기능을 필요한 시점에 사용할 수 없어 사용자가 차량을 원격으로 식별하거나 관련 편의 기능을 사용할 수 없다.
DS-14	차량의 보호 또는 제한 운용 모드가 의도하지 않게 해제되어 차량의 도난 억제, 사용 제한 효과가 감소하고 차량이 허용되지 않은 방식으로 사용될 가능성이 증가한다.
DS-15	보호 또는 제한 운용 모드가 의도하지 않게 활성화되거나 해제할 수 없게 되어 정당한 사용자의 차량 이용이 제한된다.
DS-16	원격명령의 실제 처리 결과와 사용자에게 제공되는 결과, 상태가 일치하지 않거나 결과를 확인할 수 없어 사용자가 차량 상태를 잘못 판단하거나 불필요하게 명령을 반복한다.
DS-17	차량 식별정보와 원격명령 종류, 처리 기록 등 거래 메타데이터가 권한 없는 주체에게 노출되어 차량과 사용자의 관계 또는 차량 이용 행태가 노출된다.

3.2 위협 시나리오 식별(Threat Scenario Identification)

표 11 위협 시나리오 식별 단계 목표

구분	내용
ISO/SAE 21434	15.4 Threat scenario identification
목적	위협 시나리오를 식별한다.
요구사항 및 권고사항	[RQ-15-03] 위협 시나리오는 목표 자산, 손상되는 사이버보안 속성, 해당 속성의 손상 원인을 포함해야 한다.
작업 산출물	[WP-15-03] Threat scenarios

위협 시나리오는 STRIDE 를 기본 분류체계로 사용하되, replay, stale, duplicate processing 처럼 STRIDE 한 범주로 충분히 표현하기 어려운 원격명령 특성은 합리적으로 예견 가능한 오용 시나리오로 별도 식별했다. 위협 시나리오에는 공격경로의 세부 단계나 특정 exploit 을 섞지 않았다.

표 12 위협 시나리오 식별 결과

위협 ID	목표 자산	손상 속성	손상 원인	위협 시나리오	피해 시나리오
TS-01	AS-01	무결성	Spoofing	정당한 원격 접근제어 명령으로 위장한 명령이 처리되어 차량 접근제어 명령 데이터의 무결성이 손상된다.	DS-01
TS-02	AS-01	무결성	Tampering	정상적인 잠금, 해제 명령의 동작 종류, 대상 또는 관련 제어정보가 변경되어 접근제어 명령 데이터의 무결성이 손상된다.	DS-01
TS-03	AS-01	가용성	Denial of Service	차량 접근제어 원격명령이 차단, 손실, 처리 불가 상태가 되어 접근제어 기능의 가용성이 손상된다.	DS-02

위협 ID	목표 자산	손상 속성	손상 원인	위협 시나리오	피해 시나리오
TS-04	AS-02	무결성	Spoofing	원동기, 주행 관련 정당한 명령으로 위장한 명령이 처리되어 원동기, 주행 관련 명령 데이터의 무결성이 손상된다.	DS-03, DS-04
TS-05	AS-02	무결성	Tampering	원동기, 주행 명령의 종류 또는 파라미터가 변경되어 의도한 명령과 다른 동작이 수행될 수 있도록 무결성이 손상된다.	DS-03, DS-04
TS-06	AS-02	가용성	Denial of Service	원동기, 주행 관련 원격명령의 전달 또는 처리가 불가능해져 해당 원격 기능의 가용성이 손상된다.	DS-04
TS-07	AS-03	무결성	Spoofing	정당한 개구부 제어 명령으로 위장한 명령이 처리되어 창문, 선루프, 트렁크 등 개구부 명령의 무결성이 손상된다.	DS-05, DS-06
TS-08	AS-03	무결성	Tampering	개구부 명령의 방향, 대상 또는 파라미터가 변경되어 의도하지 않은 개폐 동작이 발생할 수 있도록 무결성이 손상된다.	DS-05, DS-06
TS-09	AS-03	가용성	Denial of Service	개구부 원격제어 명령이 차단 또는 처리되지 않아 정당한 사용자가 필요한 기능을 사용할 수 없게 된다.	DS-07
TS-10	AS-04	무결성	Spoofing	정당한 열, 공조 명령으로 위장한 명령이 처리되어 공조 및 편의 제어정보의 무결성이 손상된다.	DS-08
TS-11	AS-04	무결성	Tampering	온도, 작동상태 또는 대상 편의기능 등의 명령 정보가 변경되어 사용자의 의도와 다른 열, 공조 동작이 발생한다.	DS-08
TS-12	AS-04	가용성	Denial of Service	공조, 난방, 열선 등의 원격제어가 불가능해져 해당 편의기능의 가용성이 손상된다.	DS-09
TS-13	AS-05	무결성	Spoofing	정당한 충전, 고전압 배터리 관련 명령으로 위장한 명령이 처리되어 에너지 관리 명령의 무결성이 손상된다.	DS-10, DS-11
TS-14	AS-05	무결성	Tampering	충전 시작, 정지, 전류 또는 충전한도 등의 제어정보가 변경되어 사용자의 의도와 다른 충전 동작이 발생한다.	DS-10, DS-11
TS-15	AS-05	가용성	Denial of Service	원격 충전 제어가 차단 또는 처리 불가 상태가 되어 필요한 충전 기능을 사용할 수 없게 된다.	DS-10
TS-16	AS-06	무결성	Spoofing	정당한 경적, 등화, 차량찾기 명령으로 위장한 명령이 처리되어 신호 제어정보의 무결성이 손상된다.	DS-12
TS-17	AS-06	무결성	Tampering	신호 종류, 대상 또는 동작정보가 변경되어 사용자의 의도와 다른 시각, 가청 신호가 발생한다.	DS-12
TS-18	AS-06	가용성	Denial of Service	차량찾기 또는 신호 기능의 원격명령을 처리할 수 없어 해당 기능의 가용성이 손상된다.	DS-13
TS-19	AS-07	무결성	Spoofing	정당한 보안, 운용모드 명령으로 위장한 명령이 처리되어 해당 모드 제어정보의 무결성이 손상된다.	DS-14, DS-15
TS-20	AS-07	무결성	Tampering	보안 또는 제한 운용모드 활성화, 비활성 정보가 변경되어 의도하지 않은 모드 전환이 발생한다.	DS-14, DS-15
TS-21	AS-07	가용성	Denial of Service	보안 또는 제한 운용모드에 대한 정당한 원격제어가 불가능해져 해당 기능의 가용성이 손상된다.	DS-15
TS-22	AS-08	무결성	Spoofing	다른 차량 또는 기능을 정당한 명령 대상으로 위장하여 명령과 실제 대상 간 결합의 무결성이 손상된다.	해당 기능 피해(DS-01~DS-15)
TS-23	AS-08	무결성	Tampering	명령의 대상 차량, 대상 기능 또는 내부 라우팅 정보가 변경되어 의도하지 않은 대상에 명령이 적용된다.	해당 기능 피해(DS-01~DS-15)
TS-24	AS-08	가용성	Denial of Service	대상 식별 또는 내부 라우팅 정보를 사용할 수 없어 정당한 명령을 대상 기능에 전달하지 못한다.	DS-02, DS-04, DS-07, DS-09, DS-10, DS-13, DS-15
TS-25	AS-09	무결성	Spoofing	정당한 명령 발신자 또는 허용된 명령 처리 맥락으로 위장된 정보가 사용되어 차량측 명령 처리 판단의 무결성이 손상되고, 정상 조건이라면 수락되지 않아야 할 명령이 수락될 수 있다.	DS-01, DS-03, DS-05, DS-06, DS-08, DS-10, DS-11, DS-12, DS-14, DS-15
TS-26	AS-09	무결성	Elevation of Privilege	요청 주체 또는 명령이 정상적으로 가지지 않아야 할 처리 권한을 획득하거나 수락 조건을 우회하여 차량측 명령 수락 판단의 무결성이 손상된다.	DS-01, DS-03, DS-05, DS-06, DS-08, DS-10, DS-11, DS-12, DS-14, DS-15
TS-27	AS-09	무결성	Replay / stale / duplicate processing	과거에 정당했던 명령 또는 이미 처리된 명령이 현재의 새로운 명령처럼 다시 수락되어 현재 사용자 의도와 명령 처리 상태의 일치성이 깨진다.	DS-01, DS-03, DS-04, DS-05, DS-06, DS-08, DS-10, DS-11, DS-12, DS-14, DS-15
TS-28	AS-09	무결성	Tampering	차량측 원격명령 처리조건, 판단상태 또는 처리 로직이 변경되어 수락되어야 할 명령이 거부되거나 거부되어야 할 명령이 수락된다.	해당 기능 피해(DS-01~DS-15)
TS-29	AS-09	가용성	Denial of Service	원격명령 수신, 해석 또는 수락 판단 기능이 자원고갈, 정지 또는 처리불능 상태가 되어 정당한 원격명령을 처리할 수 없게 된다.	DS-02, DS-04, DS-07, DS-09, DS-10, DS-13, DS-15
TS-30	AS-10	기밀성	Information Disclosure	원격명령의 대상 차량, 명령 종류, 실행 결과 또는 관련 거래 메타데이터가 권한 없는 주체에게 노출되어 해당 정보의 기밀성이 손상된다.	DS-17

위협 ID	목표 자산	손상 속성	손상 원인	위협 시나리오	피해 시나리오
TS-31	AS-10	무결성	Spoofing	실제 차량 상태 또는 명령 처리 결과와 다른 상태정보가 정상 결과로 위장되어 사용자에게 제공됨으로써 결과정보의 무결성이 손상된다.	DS-16
TS-32	AS-10	무결성	Tampering	정상적으로 생성된 명령 처리 결과, 상태, 거래 메타데이터가 변경되어 실제 처리 결과와 보고 결과가 일치하지 않게 된다.	DS-16
TS-33	AS-10	가용성	Denial of Service	처리 결과 또는 상태정보가 차단, 삭제, 전달 실패하여 사용자가 원격명령의 처리결과를 확인할 수 없다.	DS-16
TS-34	AS-10	무결성/가용성	Repudiation	원격명령의 발생, 처리, 실행에 대한 거래정보가 충분히 보존 또는 검증되지 않아 명령의 발생이나 처리 사실을 부인할 수 있게 되고, 명령 처리 이력의 신뢰성이 손상된다.	DS-16
TS-35	AS-11	무결성	Spoofing	차량 내부에서 정당한 원격명령 전달 데이터로 위장한 제어데이터가 대상 기능에 전달된다.	해당 기능 피해(DS-01~DS-15)
TS-36	AS-11	무결성	Tampering	차량 내부 전달 중 명령 종류, 대상 또는 파라미터 등이 변경되어 원래 수락된 명령과 다른 제어정보가 대상 기능에 전달된다.	해당 기능 피해(DS-01~DS-15)
TS-37	AS-11	가용성	Denial of Service	수락된 원격명령의 차량 내부 전달이 차단되어 대상 기능이 정당한 명령을 수신하지 못한다.	DS-02, DS-04, DS-07, DS-09, DS-10, DS-13, DS-15
TS-38	AS-12	무결성	Tampering	원격명령 대상 차량 기능을 구현하는 SW/FW 가 변조되어 정상 명령에 대해 의도하지 않은 차량 기능이 수행되거나 정상 기능이 변경된다.	해당 기능 피해(DS-01~DS-15)
TS-39	AS-12	가용성	Denial of Service	대상 기능 제어 SW/FW 또는 실행환경을 사용할 수 없게 되어 정당한 원격명령에 따른 차량 기능을 수행하지 못한다.	DS-02, DS-04, DS-07, DS-09, DS-10, DS-13, DS-15
TS-40	AS-12	무결성	Elevation of Privilege	대상 기능 제어기에서 허용되지 않은 높은 권한의 실행 또는 제어 권한을 획득하여 정상 원격명령 경로를 우회한 차량 기능 제어가 가능해진다.	해당 기능 피해(DS-01~DS-15)
TS-41	AS-13	무결성	Spoofing	원격명령 판단에 사용되는 실제 차량 상태 또는 운용조건과 다른 허위 상태정보가 정상 입력으로 위장되어 판단 정보의 무결성이 손상된다.	해당 기능 피해(DS-01~DS-15)
TS-42	AS-13	무결성	Tampering	차량 상태정보가 생성 지점과 원격명령 처리 지점 사이에서 변경되어 실제 차량 상태와 다른 값이 명령 수락 판단에 사용된다.	해당 기능 피해(DS-01~DS-15)
TS-43	AS-13	가용성	Denial of Service	원격명령 수락 판단에 필요한 차량 상태, 운용조건 정보를 사용할 수 없게 되어 상태기반 판단 기능의 가용성이 손상된다.	DS-02, DS-04, DS-07, DS-09, DS-10, DS-13, DS-15

3.3 영향 등급(Impact Rating)

표 13 영향 등급 평가 단계 목표

구분	내용
ISO/SAE 21434	15.5 Impact rating
목적	피해 시나리오의 영향 등급을 결정한다.
요구사항 및 권고사항	[RQ-15-04] 피해 시나리오를 안전, 재무, 운영, 개인정보(S/F/O/P) 관점에서 평가한다. [RQ-15-05] 각 범주를 Severe, Major, Moderate, Negligible 중 하나로 결정한다. [RQ-15-06] Safety 는 ISO 26262-3:2018 기준에서 파생한다.
작업 산출물	[WP-15-04] Impact ratings with associated impact categories

표 14 영향 등급 평가 기준

영향 등급	안전(S)	재무(F)	운영(O)	개인정보(P)
-------	-------	-------	-------	---------

영향 등급	안전(S)	재무(F)	운영(O)	개인정보(P)
심각한(Severe)	S3: 생존 불확실 수준의 생명위협 또는 사망	영향받는 사용자가 극복하기 어려운 파국적 경제손실	Core vehicle function 상실 또는 중대한 비정상 동작	매우 민감하고 PII 와 쉽게 연결되는 정보의 중대한 노출
주요한(Major)	S2: 생존 가능성이 있는 심각, 생명위협 상해	상당하지만 극복 가능한 경제손실	Important vehicle function 상실 또는 손상	심각한 개인정보 영향
보통의(Moderate)	S1: 경상 또는 중등도 상해	제한된 자원으로 극복 가능한 불편한 경제손실	차량 기능의 부분적 저하	불편한 수준의 개인정보 영향
무시할 수 있는(Negligible)	S0: 상해 없음	영향 없음 또는 미미	기능 저하가 없거나 인지하기 어려움	영향 없음 또는 미미

표 15 피해 시나리오별 영향 등급 평가

ID	피해 시나리오	안전	재무	운영	개인정보	평가 근거
DS-01	차량의 잠금 상태가 정당한 사용자의 의도와 다르게 변경되어 차량 또는 차량 내 물품에 대한 비인가 물리적 접근이 가능해진다.	무시할 수 있는	보통의	보통의	무시할 수 있는	비인가 물리적 접근 가능성은 접근제어 기능의 손상으로 보며, 일반적인 reference 평가에서는 제한적인 재산상 영향과 부분 기능 저하를 반영한다.
DS-02	정당한 사용자가 필요한 시점에 차량의 잠금/해제 상태를 원격으로 변경하지 못해 정상적인 차량 접근 또는 차량 보호 기능을 이용하지 못한다.	무시할 수 있는	무시할 수 있는	보통의	무시할 수 있는	원격 잠금, 해제 기능을 사용할 수 없는 상태로, 직접적인 상해나 개인정보 노출보다 기능 저하가 중심이다.
DS-03	원동기 작동 또는 원격 주행 가능 상태가 의도하지 않게 활성화되어 차량이 사용자의 의도와 다른 동작 가능 상태가 되고, 조건에 따라 차량 또는 도로 사용자에게 위해가 발생할 수 있다.	주요한	보통의	심각한	무시할 수 있는	원동기, 주행 가능 상태의 의도치 않은 활성화는 심각한 상해 가능성을 배제할 수 없고 core vehicle function 의 비정상 동작에 해당한다.
DS-04	원동기 또는 주행 관련 상태가 의도하지 않게 중지, 비활성화되거나 필요한 기능을 사용할 수 없어 차량 이동성이 상실되며, 운행 조건에 따라 도로 사용자에게 위해가 발생할 수 있다.	주요한	보통의	심각한	무시할 수 있는	원동기, 주행 기능의 의도치 않은 상실은 심각한 상해 가능성과 core mobility 기능 상실을 수반할 수 있다.
DS-05	창문, 선루프, 트렁크, 프렁크, 충전구 등의 개구부가 의도하지 않게 열리거나 열린 상태가 되어 차량 내부 또는 적재물의 보호가 저하된다.	무시할 수 있는	보통의	보통의	무시할 수 있는	개구부 보호 저하로 제한적인 재산상 영향과 부분 기능 저하가 발생할 수 있으나 현재 시나리오 자체에 신체 상해는 포함하지 않는다.
DS-06	전동 개구부가 의도하지 않은 시점에 닫히거나 움직여 주변 사람 또는 물체와 충돌, 끼임이 발생할 수 있다.	보통의	보통의	보통의	무시할 수 있는	전동 개구부의 비정상 동작은 일반적으로 경상 또는 중등도 상해 가능성을 고려하며, 부분 기능 저하와 제한적 비용을 동반할 수 있다.
DS-07	정당한 사용자가 필요한 개구부를 원격으로 조작하지 못하여 차량을 정상적으로 사용하거나 보호하지 못한다.	무시할 수 있는	무시할 수 있는	보통의	무시할 수 있는	정상 원격 개구부 기능 사용 불가가 주된 영향이다.
DS-08	공조, 보조난방, 유리열선, 좌석, 스티어링 난방 등이 의도하지 않게 작동하거나 설정되어 불필요한 에너지 소비 또는 의도하지 않은 실내 열환경이 발생한다.	무시할 수 있는	보통의	보통의	무시할 수 있는	의도하지 않은 공조, 난방 동작으로 제한적인 에너지 비용과 부분 기능 저하가 발생할 수 있다.
DS-09	필요한 원격 열, 공조 기능을 사용할 수 없어 사전 공조 또는 관련 편의 기능을 정상적으로 이용하지 못한다.	무시할 수 있는	무시할 수 있는	보통의	무시할 수 있는	편의 기능의 원격 사용 불가로 부분적인 운용 저하가 발생한다.
DS-10	충전이 의도하지 않게 중지되거나 충전 한도가 감소하거나 충전 제어가 불가능하여 필요한 시점에 충분한 배터리 충전량을 확보하지 못하고 차량의 이용 가능성이 저하된다.	무시할 수 있는	보통의	주요한	무시할 수 있는	필요한 충전량을 확보하지 못하면 차량 이용 가능성이 상당히 저하되며 추가 비용이 발생할 수 있다.
DS-11	충전이 의도하지 않게 시작되거나 충전 전류, 한도 등이 변경되어 사용자가 의도하지 않은 에너지 소비 또는 비용이 발생한다.	무시할 수 있는	보통의	보통의	무시할 수 있는	비인가 충전 또는 충전 설정 변경으로 제한적인 경제손실과 부분 운용 저하가 발생할 수 있다.
DS-12	경적, 등화, 비상등 등의 외부 신호가 의도하지 않게 작동하여 차량 주변 사람 또는 다른 도로 사용자에게 잘못된 신호를 제공하거나 주의를 분산시킨다.	무시할 수 있는	무시할 수 있는	보통의	무시할 수 있는	현재 피해 정의는 잘못된 외부 신호와 주의분산까지이며 충돌, 상해를 직접 포함하지 않는다.
DS-13	차량 찾기 또는 원격 신호 기능을 필요한 시점에 사용할 수 없어 사용자가 차량을 원격으로 식별하거나 관련 편의 기능을 사용할 수 없다.	무시할 수 있는	무시할 수 있는	보통의	무시할 수 있는	차량찾기 및 원격 신호 기능의 사용 불가가 주된 영향이다.

ID	피해 시나리오	안전	재무	운영	개인정보	평가 근거
DS-14	차량의 보호 또는 제한 운용 모드가 의도하지 않게 해제되어 차량의 도난 억제, 사용 제한 효과가 감소하고 차량이 허용되지 않은 방식으로 사용될 가능성이 증가한다.	무시할 수 있는	보통의	보통의	무시할 수 있는	보호, 제한 기능 저하는 제한적인 재산상 영향과 부분 기능 저하로 평가한다.
DS-15	보호 또는 제한 운용 모드가 의도하지 않게 활성화되거나 해제할 수 없게 되어 정당한 사용자의 차량 이용이 제한된다.	무시할 수 있는	무시할 수 있는	보통의	무시할 수 있는	정당한 사용자의 차량 이용 제한이 중심이며 core vehicle function 상실로 확대하지 않는다.
DS-16	원격명령의 실제 처리 결과와 사용자에게 제공되는 결과, 상태가 일치하지 않거나 결과를 확인할 수 없어 사용자가 차량 상태를 잘못 판단하거나 불필요하게 명령을 반복한다.	무시할 수 있는	무시할 수 있는	보통의	무시할 수 있는	실행 결과와 보고 상태의 불일치는 사용자의 판단과 원격 기능 운용을 저하시킨다.
DS-17	차량 식별정보와 원격명령 종류, 처리 기록 등 거래 메타데이터가 권한 없는 주체에게 노출되어 차량과 사용자의 관계 또는 차량 이용 행태가 노출된다.	무시할 수 있는	무시할 수 있는	무시할 수 있는	보통의	거래 메타데이터가 사용자 계정과 연결될 수 있다는 reference assumption 아래 이용행태 정보 노출을 Moderate 로 평가한다.

3.4 공격 경로 분석(Attack Path Analysis)

표 16 공격 경로 식별 단계 목표

구분	내용
ISO/SAE 21434	15.6 Attack path analysis
목적	위협 시나리오를 실현하는 공격 경로를 식별한다.
요구사항 및 권고사항	[RQ-15-08] 위협 시나리오를 분석해 공격 경로를 식별한다. [RQ-15-09] 공격 경로를 해당 경로가 실현하는 위협 시나리오와 연결한다.
작업 산출물	[WP-15-05] Attack paths

공격 경로는 **reference architecture** 를 기준으로 **top-down** 방식으로 도출했다. 알려진 **connected-car mobile application** 취약점 유형과 ISO/SAE 21434 Annex H 의 셀룰러, 차량 내부 네트워크, OBD 접근 예시는 경로의 현실성 검토에 사용했지만 특정 OEM 에 동일한 취약점이 존재한다고 전제하지 않았다.

표 17 공격 경로 상세

공격 경로 ID	공격 경로	세부 단계
AP-01	사용자 인증문맥 탈취 후 정상 명령 경로 악용	1) 공격자가 정당한 사용자의 remote-service 인증정보 또는 세션을 획득한다. 2) 정상 Mobile/API 인터페이스로 원격명령을 요청한다. 3) Backend 가 탈취된 인증문맥을 정당한 사용자 요청으로 처리한다. 4) Command Service 가 명령을 대상 차량으로 전달한다. 5) 차량 C-01/C-02 가 정상 명령 형식으로 수신하고 C-03 이 수락한다. 6) C-04 를 통해 C-05 로 전달되어 차량 기능이 실행된다.
AP-02	대상 차량 바인딩 또는 객체 수준 인가 실패 악용	1) 공격자가 자신의 정상 계정 또는 유효 세션을 확보한다. 2) 원격명령 요청의 vehicle identifier 또는 대상 resource 를 다른 차량으로 지정한다. 3) Backend 가 사용자와 대상 차량의 권한 관계를 충분히 검증하지 못한다. 4) 명령이 공격자가 소유하지 않은 차량으로 전달된다. 5) 차량이 정상 요청으로 처리하여 의도하지 않은 차량 기능이 실행된다.

공격 경로 ID	공격 경로	세부 단계
AP-03	Backend / Command Service 침해	1) 공격자가 Backend 또는 Command Service 의 실행권한을 획득한다. 2) 정상 사용자 요청 없이 명령을 생성하거나 정상 명령을 변경한다. 3) 침해된 서비스가 기존 차량 통신 경로를 이용해 명령을 전달한다. 4) 차량 C-01/C-02 가 명령을 수신하고 처리한다. 5) C-04 를 거쳐 대상 기능으로 전달되어 의도하지 않은 차량 기능이 실행된다.
AP-04	정상 명령 Replay	1) 공격자가 과거에 정상적으로 생성된 원격명령을 획득한다. 2) 원래 명령이 정상적으로 처리된다. 3) 공격자가 동일하거나 동등한 명령을 이후 시점에 다시 제출한다. 4) freshness 또는 uniqueness 검증이 충분하지 않으면 차량이 새로운 명령으로 처리한다. 5) 동일 차량 기능이 다시 실행된다.
AP-05	외부 통신 구간 가로채기, 변경, 차단	1) 공격자가 Client-Backend 또는 Backend-Vehicle 사이 통신경로에 개입한다. 2) 명령 또는 상태 메시지를 관찰한다. 3) 통신 상대 인증이나 메시지 무결성 보호가 충분하지 않은 경우 데이터를 변경, 재전송 또는 차단한다. 4) 변조된 명령, 상태정보가 수신자에게 전달되거나 정상 메시지가 전달되지 않는다. 5) Item 또는 사용자가 잘못된 명령이나 상태를 처리한다.
AP-06	차량 외부 통신 Endpoint 원격 침해	1) 공격자가 차량의 외부 네트워크 인터페이스에 접근한다. 2) C-01 또는 C-02 의 네트워크 서비스나 입력 처리 취약점을 악용한다. 3) 차량 communication endpoint 에서 코드 실행 또는 동등한 제어권을 획득한다. 4) 내부 command-processing interface 에 접근해 악의적 명령을 생성한다. 5) C-03/C-04 를 거쳐 대상 Controller 로 전달되어 차량 기능이 실행된다.
AP-07	차량 외부 Command Endpoint DoS	1) 공격자가 차량 외부 command endpoint 에 반복 요청 또는 비정상 입력을 전송한다. 2) C-01/C-02 의 통신, 메모리, CPU 또는 connection 자원이 고갈되거나 service 가 비정상 상태가 된다. 3) 정상 원격명령을 수신 또는 처리하지 못한다. 4) 사용자의 정상 원격기능 요청이 실패한다.
AP-08	진단, 정비 인터페이스를 통한 내부 접근	1) 공격자가 차량의 진단 인터페이스에 물리적으로 접근하거나 정비 장비를 장악한다. 2) 진단 인터페이스를 통해 gateway 또는 내부 network 에 접근한다. 3) 진단 서비스 또는 내부 메시지를 이용해 차량측 component 를 제어한다. 4) 정상 remote-command 처리경로를 우회해 대상 Controller 또는 내부 command channel 에 접근한다. 5) 차량 기능에 영향을 준다.
AP-09	침해된 차량 내부 노드에서 제어메시지 Spoofing	1) 차량 내부 네트워크에 연결된 component 가 침해된다. 2) 침해된 component 가 정상 command source 와 같은 형태의 내부 제어 메시지를 생성한다. 3) 메시지가 C-04 또는 C-05 로 전달된다. 4) 대상 Controller 가 정상 제어명령으로 처리한다. 5) 차량 기능이 의도하지 않게 실행된다.
AP-10	Gateway 또는 Routing Component 변조	1) 공격자가 C-04 Gateway / Internal Routing component 의 제어권을 획득한다. 2) 정상적으로 수락된 command 의 destination, function identifier 또는 payload 를 변경한다. 3) 변경된 명령을 원래와 다른 Controller 또는 기능으로 전달한다. 4) Target Controller 가 수정된 명령을 처리한다. 5) 사용자가 요청하지 않은 기능이 수행된다.
AP-11	차량 내부 네트워크 DoS	1) 공격자가 내부 네트워크에 접근 가능한 component 또는 diagnostic interface 를 확보한다. 2) 과도한 메시지 전송, network resource 점유 또는 정상 통신 방해를 수행한다. 3) Remote command, vehicle state 또는 result message 가 지연되거나 손실된다. 4) Target Controller 또는 Command Processor 가 필요한 메시지를 수신하지 못한다. 5) 원격 차량 기능을 사용할 수 없게 된다.

공격 경로 ID	공격 경로	세부 단계
AP-12	차량측 Command Processing Logic 변조	1) 공격자가 C-02 또는 C-03 에 privileged access 를 획득한다. 2) 명령 parser, acceptance condition, configuration 또는 processing state 를 변경한다. 3) 이후 들어오는 정상 명령에 대해 잘못된 수락 또는 거부 판단을 수행한다. 4) 거부되어야 할 명령이 차량 내부로 전달되거나 정상 명령이 차단된다.
AP-13	Target Function Controller SW/FW 침해	1) 공격자가 내부 네트워크, 진단, 정비 기능 또는 software update 경로를 통해 C-05 에 접근한다. 2) Controller 의 SW/FW 또는 runtime state 에 대한 높은 권한을 획득한다. 3) 정상 제어 SW/FW 를 변경하거나 정상 실행을 중단한다. 4) Remote command 에 대한 동작이 변경되거나 command 와 무관하게 기능을 제어한다. 5) 차량 기능이 비정상적으로 실행되거나 사용할 수 없게 된다.
AP-14	Vehicle State Input Spoofing / Tampering	1) 공격자가 vehicle state 를 생성하는 ECU 또는 state communication channel 을 침해한다. 2) speed, gear, ignition, charging state 등의 값을 허위로 생성하거나 변경한다. 3) 잘못된 상태정보가 C-03 에 전달된다. 4) C-03 이 실제 차량 상태와 다른 조건을 기준으로 명령을 평가한다. 5) 허용되지 않아야 할 명령이 수락되거나 정상 명령이 거부된다.
AP-15	Vehicle State Input DoS	1) 공격자가 vehicle state source 또는 해당 통신경로를 방해한다. 2) C-03 이 필요한 vehicle state 를 수신하지 못한다. 3) Command Processing 이 필요한 운용조건을 평가하지 못한다. 4) 구현의 실패 처리 정책에 따라 정상 명령이 차단되거나 잘못된 판단이 발생할 수 있다.
AP-16	Transaction / Result Evidence 변조	1) 공격자가 command handler 또는 transaction/result 저장영역에 privileged access 를 획득한다. 2) 명령 발생, 수락, 실행, 실패와 관련된 기록을 삭제하거나 수정한다. 3) 실제 실행 내역과 저장된 transaction evidence 가 달라진다. 4) 명령의 발생 또는 처리 사실을 신뢰성 있게 확인할 수 없게 된다.

표 18 위협 시나리오-공격 경로 매핑

위협 ID	자산	위협 시나리오	공격 경로
TS-01	AS-01	정당한 원격 접근제어 명령으로 위장한 명령이 처리되어 차량 접근제어 명령 데이터의 무결성이 손상된다.	AP-01: 사용자 인증문맥 탈취 후 정상 명령 경로 악용 AP-03: Backend / Command Service 침해 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-09: 침해된 차량 내부 노드에서 제어메시지 Spoofing
TS-02	AS-01	정상적인 잠금, 해제 명령의 동작 종류, 대상 또는 관련 제어정보가 변경되어 접근제어 명령 데이터의 무결성이 손상된다.	AP-03: Backend / Command Service 침해 AP-05: 외부 통신 구간 가로채기, 변경, 차단 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-10: Gateway 또는 Routing Component 변조 AP-12: 차량측 Command Processing Logic 변조
TS-03	AS-01	차량 접근제어 원격명령이 차단, 손실, 처리 불가 상태가 되어 접근제어 기능의 가용성이 손상된다.	AP-07: 차량 외부 Command Endpoint DoS AP-11: 차량 내부 네트워크 DoS
TS-04	AS-02	원동기, 주행 관련 정당한 명령으로 위장한 명령이 처리되어 원동기, 주행 관련 명령 데이터의 무결성이 손상된다.	AP-01: 사용자 인증문맥 탈취 후 정상 명령 경로 악용 AP-03: Backend / Command Service 침해 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-09: 침해된 차량 내부 노드에서 제어메시지 Spoofing

위협 ID	자산	위협 시나리오	공격 경로
TS-05	AS-02	원동기, 주행 명령의 종류 또는 파라미터가 변경되어 의도한 명령과 다른 동작이 수행될 수 있도록 무결성이 손상된다.	AP-03: Backend / Command Service 침해 AP-05: 외부 통신 구간 가로채기, 변경, 차단 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-10: Gateway 또는 Routing Component 변조 AP-12: 차량측 Command Processing Logic 변조
TS-06	AS-02	원동기, 주행 관련 원격명령의 전달 또는 처리가 불가능해져 해당 원격 기능의 가용성이 손상된다.	AP-07: 차량 외부 Command Endpoint DoS AP-11: 차량 내부 네트워크 DoS
TS-07	AS-03	정당한 개구부 제어 명령으로 위장한 명령이 처리되어 창문, 선루프, 트렁크 등 개구부 명령의 무결성이 손상된다.	AP-01: 사용자 인증문맥 탈취 후 정상 명령 경로 악용 AP-03: Backend / Command Service 침해 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-09: 침해된 차량 내부 노드에서 제어메시지 Spoofing
TS-08	AS-03	개구부 명령의 방향, 대상 또는 파라미터가 변경되어 의도하지 않은 개폐 동작이 발생할 수 있도록 무결성이 손상된다.	AP-03: Backend / Command Service 침해 AP-05: 외부 통신 구간 가로채기, 변경, 차단 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-10: Gateway 또는 Routing Component 변조 AP-12: 차량측 Command Processing Logic 변조
TS-09	AS-03	개구부 원격제어 명령이 차단 또는 처리되지 않아 정당한 사용자가 필요한 기능을 사용할 수 없게 된다.	AP-07: 차량 외부 Command Endpoint DoS AP-11: 차량 내부 네트워크 DoS
TS-10	AS-04	정당한 열, 공조 명령으로 위장한 명령이 처리되어 공조 및 편의 제어정보의 무결성이 손상된다.	AP-01: 사용자 인증문맥 탈취 후 정상 명령 경로 악용 AP-03: Backend / Command Service 침해 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-09: 침해된 차량 내부 노드에서 제어메시지 Spoofing
TS-11	AS-04	온도, 작동상태 또는 대상 편의기능 등의 명령 정보가 변경되어 사용자의 의도와 다른 열, 공조 동작이 발생한다.	AP-03: Backend / Command Service 침해 AP-05: 외부 통신 구간 가로채기, 변경, 차단 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-10: Gateway 또는 Routing Component 변조 AP-12: 차량측 Command Processing Logic 변조
TS-12	AS-04	공조, 난방, 열선 등의 원격제어가 불가능해져 해당 편의기능의 가용성이 손상된다.	AP-07: 차량 외부 Command Endpoint DoS AP-11: 차량 내부 네트워크 DoS
TS-13	AS-05	정당한 충전, 고전압 배터리 관련 명령으로 위장한 명령이 처리되어 에너지 관리 명령의 무결성이 손상된다.	AP-01: 사용자 인증문맥 탈취 후 정상 명령 경로 악용 AP-03: Backend / Command Service 침해 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-09: 침해된 차량 내부 노드에서 제어메시지 Spoofing
TS-14	AS-05	충전 시작, 정지, 전류 또는 충전한도 등의 제어정보가 변경되어 사용자의 의도와 다른 충전 동작이 발생한다.	AP-03: Backend / Command Service 침해 AP-05: 외부 통신 구간 가로채기, 변경, 차단 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-10: Gateway 또는 Routing Component 변조 AP-12: 차량측 Command Processing Logic 변조
TS-15	AS-05	원격 충전 제어가 차단 또는 처리 불가 상태가 되어 필요한 충전 기능을 사용할 수 없게 된다.	AP-07: 차량 외부 Command Endpoint DoS AP-11: 차량 내부 네트워크 DoS
TS-16	AS-06	정당한 경적, 등화, 차량찾기 명령으로 위장한 명령이 처리되어 신호 제어정보의 무결성이 손상된다.	AP-01: 사용자 인증문맥 탈취 후 정상 명령 경로 악용 AP-03: Backend / Command Service 침해 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-09: 침해된 차량 내부 노드에서 제어메시지 Spoofing

위협 ID	자산	위협 시나리오	공격 경로
TS-17	AS-06	신호 종류, 대상 또는 동작정보가 변경되어 사용자의 의도와 다른 시각, 가청 신호가 발생한다.	AP-03: Backend / Command Service 침해 AP-05: 외부 통신 구간 가로채기, 변경, 차단 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-10: Gateway 또는 Routing Component 변조 AP-12: 차량측 Command Processing Logic 변조
TS-18	AS-06	차량찾기 또는 신호 기능의 원격명령을 처리할 수 없어 해당 기능의 가용성이 손상된다.	AP-07: 차량 외부 Command Endpoint DoS AP-11: 차량 내부 네트워크 DoS
TS-19	AS-07	정당한 보안, 운용모드 명령으로 위장한 명령이 처리되어 해당 모드 제어정보의 무결성이 손상된다.	AP-01: 사용자 인증문맥 탈취 후 정상 명령 경로 악용 AP-03: Backend / Command Service 침해 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-09: 침해된 차량 내부 노드에서 제어메시지 Spoofing
TS-20	AS-07	보안 또는 제한 운용모드 활성화, 비활성 정보가 변경되어 의도하지 않은 모드 전환이 발생한다.	AP-03: Backend / Command Service 침해 AP-05: 외부 통신 구간 가로채기, 변경, 차단 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-10: Gateway 또는 Routing Component 변조 AP-12: 차량측 Command Processing Logic 변조
TS-21	AS-07	보안 또는 제한 운용모드에 대한 정당한 원격제어가 불가능해져 해당 기능의 가용성이 손상된다.	AP-07: 차량 외부 Command Endpoint DoS AP-11: 차량 내부 네트워크 DoS
TS-22	AS-08	다른 차량 또는 기능을 정당한 명령 대상으로 위장하여 명령과 실제 대상 간 결합의 무결성이 손상된다.	AP-02: 대상 차량 바인딩 또는 객체 수준 인가 실패 악용 AP-03: Backend / Command Service 침해 AP-10: Gateway 또는 Routing Component 변조
TS-23	AS-08	명령의 대상 차량, 대상 기능 또는 내부 라우팅 정보가 변경되어 의도하지 않은 대상에 명령이 적용된다.	AP-02: 대상 차량 바인딩 또는 객체 수준 인가 실패 악용 AP-03: Backend / Command Service 침해 AP-05: 외부 통신 구간 가로채기, 변경, 차단 AP-10: Gateway 또는 Routing Component 변조
TS-24	AS-08	대상 식별 또는 내부 라우팅 정보를 사용할 수 없어 정당한 명령을 대상 기능에 전달하지 못한다.	AP-11: 차량 내부 네트워크 DoS AP-12: 차량측 Command Processing Logic 변조
TS-25	AS-09	정당한 명령 발신자 또는 허용된 명령 처리 맥락으로 위장된 정보가 사용되어 차량측 명령 처리 판단의 무결성이 손상되고, 정상 조건이라면 수락되지 않아야 할 명령이 수락될 수 있다.	AP-01: 사용자 인증문맥 탈취 후 정상 명령 경로 악용 AP-02: 대상 차량 바인딩 또는 객체 수준 인가 실패 악용 AP-03: Backend / Command Service 침해
TS-26	AS-09	요청 주체 또는 명령이 정상적으로 가지지 않아야 할 처리 권한을 획득하거나 수락 조건을 우회하여 차량측 명령 수락 판단의 무결성이 손상된다.	AP-02: 대상 차량 바인딩 또는 객체 수준 인가 실패 악용 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-12: 차량측 Command Processing Logic 변조
TS-27	AS-09	과거에 정당했던 명령 또는 이미 처리된 명령이 현재의 새로운 명령처럼 다시 수락되어 현재 사용자 의도와 명령 처리 상태의 일치성이 깨진다.	AP-04: 정상 명령 Replay
TS-28	AS-09	차량측 원격명령 처리조건, 판단상태 또는 처리 로직이 변경되어 수락되어야 할 명령이 거부되거나 거부되어야 할 명령이 수락된다.	AP-12: 차량측 Command Processing Logic 변조
TS-29	AS-09	원격명령 수신, 해석 또는 수락 판단 기능이 자원고갈, 정지 또는 처리불능 상태가 되어 정당한 원격명령을 처리할 수 없게 된다.	AP-07: 차량 외부 Command Endpoint DoS AP-12: 차량측 Command Processing Logic 변조
TS-30	AS-10	원격명령의 대상 차량, 명령 종류, 실행 결과 또는 관련 거래 메타데이터가 권한 없는 주체에게 노출되어 해당 정보의 기밀성이 손상된다.	AP-05: 외부 통신 구간 가로채기, 변경, 차단 AP-06: 차량 외부 통신 Endpoint 원격 침해
TS-31	AS-10	실제 차량 상태 또는 명령 처리 결과와 다른 상태정보가 정상 결과로 위장되어 사용자에게 제공됨으로써 결과정보의 무결성이 손상된다.	AP-05: 외부 통신 구간 가로채기, 변경, 차단 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-12: 차량측 Command Processing Logic 변조

위협 ID	자산	위협 시나리오	공격 경로
TS-32	AS-10	정상적으로 생성된 명령 처리 결과, 상태, 거래 메타데이터가 변경되어 실제 처리 결과와 보고 결과가 일치하지 않게 된다.	AP-05: 외부 통신 구간 가로채기, 변경, 차단 AP-06: 차량 외부 통신 Endpoint 원격 침해 AP-12: 차량측 Command Processing Logic 변조
TS-33	AS-10	처리 결과 또는 상태정보가 차단, 삭제, 전달 실패하여 사용자가 원격명령의 처리결과를 확인할 수 없다.	AP-05: 외부 통신 구간 가로채기, 변경, 차단 AP-07: 차량 외부 Command Endpoint DoS AP-11: 차량 내부 네트워크 DoS
TS-34	AS-10	원격명령의 발생, 처리, 실행에 대한 거래정보가 충분히 보존 또는 검증되지 않아 명령의 발생이나 처리 사실을 부인할 수 있게 되고, 명령 처리 이력의 신뢰성이 손상된다.	AP-16: Transaction / Result Evidence 변조
TS-35	AS-11	차량 내부에서 정당한 원격명령 전달 데이터로 위장한 제어데이터가 대상 기능에 전달된다.	AP-08: 진단, 정비 인터페이스를 통한 내부 접근 AP-09: 침해된 차량 내부 노드에서 제어메시지 Spoofing
TS-36	AS-11	차량 내부 전달 중 명령 종류, 대상 또는 파라미터 등이 변경되어 원래 수락된 명령과 다른 제어정보가 대상 기능에 전달된다.	AP-10: Gateway 또는 Routing Component 변조
TS-37	AS-11	수락된 원격명령의 차량 내부 전달이 차단되어 대상 기능이 정당한 명령을 수신하지 못한다.	AP-11: 차량 내부 네트워크 DoS
TS-38	AS-12	원격명령 대상 차량 기능을 구현하는 SW/FW 가 변조되어 정상 명령에 대해 의도하지 않은 차량 기능이 수행되거나 정상 기능이 변경된다.	AP-13: Target Function Controller SW/FW 침해
TS-39	AS-12	대상 기능 제어 SW/FW 또는 실행환경을 사용할 수 없게 되어 정당한 원격명령에 따른 차량 기능을 수행하지 못한다.	AP-13: Target Function Controller SW/FW 침해
TS-40	AS-12	대상 기능 제어기에서 허용되지 않은 높은 권한의 실행 또는 제어 권한을 획득하여 정상 원격명령 경로를 우회한 차량 기능 제어가 가능해진다.	AP-13: Target Function Controller SW/FW 침해
TS-41	AS-13	원격명령 판단에 사용되는 실제 차량 상태 또는 운용조건과 다른 허위 상태정보가 정상 입력으로 위장되어 판단 정보의 무결성이 손상된다.	AP-14: Vehicle State Input Spoofing / Tampering
TS-42	AS-13	차량 상태정보가 생성 지점과 원격명령 처리 지점 사이에서 변경되어 실제 차량 상태와 다른 값이 명령 수락 판단에 사용된다.	AP-14: Vehicle State Input Spoofing / Tampering
TS-43	AS-13	원격명령 수락 판단에 필요한 차량 상태, 운용조건 정보를 사용할 수 없게 되어 상태기반 판단 기능의 가용성이 손상된다.	AP-15: Vehicle State Input DoS

3.5 공격 실현 가능성 등급(Attack Feasibility Rating)

표 19 공격 실현 가능성 평가 단계 목표

구분	내용
ISO/SAE 21434	15.7 Attack feasibility rating
목적	각 공격 경로를 악용하는 데 필요한 공격 노력의 수준을 결정한다.
요구사항 및 권고사항	[RQ-15-10] 각 공격 경로에 대해 High, Medium, Low, Very Low 중 하나의 공격 실현 가능성 등급을 결정한다. 본 분석은 Attack Potential 기반 접근을 사용한다.
작업 산출물	[WP-15-06] Attack feasibility ratings

표 20 Attack Potential 평가 점수

평가 요소	점수 기준
경과 시간(ET)	1 일 이하=0, 1 주 이하=1, 1 개월 이하=4, 6 개월 이하=17, 6 개월 초과=19
전문성(SE)	비전문가=0, 숙련자=3, 전문가=6, 복수 분야 전문가=8

평가 요소	점수 기준
아이템 지식(KoIC)	공개=0, 제한=3, 기밀=7, 엄격한 기밀=11
기회의 창(WoO)	제한 없음=0, 쉬움=1, 보통=4, 어려움/없음=10
장비(Eq)	표준=0, 전문=4, 맞춤=7, 다중 맞춤=9
최종 매핑	0~13=높음, 14~19=중간, 20~24=낮음, 25 이상=매우 낮음

표 21 공격 실현 가능성 기반 평가

AP	공격 경로	ET	SE	KoIC	WoO	Eq	합계	등급
AP-01	사용자 인증문맥 탈취 후 정상 명령 경로 악용	1	3	0	1	0	5	높음
AP-02	대상 차량 바인딩 또는 객체 수준 인가 실패 악용	0	3	0	0	0	3	높음
AP-03	Backend / Command Service 침해	4	6	3	0	4	17	중간
AP-04	정상 명령 Replay	0	3	0	1	0	4	높음
AP-05	외부 통신 구간 가로채기, 변경, 차단	1	3	0	1	0	5	높음
AP-06	차량 외부 통신 Endpoint 원격 침해	1	8	7	0	4	20	낮음
AP-07	차량 외부 Command Endpoint DoS	0	3	0	0	0	3	높음
AP-08	진단, 정비 인터페이스를 통한 내부 접근	1	6	3	4	0	14	중간
AP-09	침해된 차량 내부 노드에서 제어메시지 Spoofing	1	6	3	4	0	14	중간
AP-10	Gateway 또는 Routing Component 변조	4	6	3	4	0	17	중간
AP-11	차량 내부 네트워크 DoS	0	3	3	4	0	10	높음
AP-12	차량측 Command Processing Logic 변조	4	6	7	4	4	25	매우 낮음
AP-13	Target Function Controller SW/FW 침해	4	8	3	10	4	29	매우 낮음
AP-14	Vehicle State Input Spoofing / Tampering	1	6	3	4	0	14	중간
AP-15	Vehicle State Input DoS	0	3	3	4	0	10	높음
AP-16	Transaction / Result Evidence 변조	4	6	7	4	4	25	매우 낮음

점수는 ISO/SAE 21434 Annex G 의 예시 매핑을 reference Item 에 일관되게 적용한 값이다. 제품별 실제 설계와 접근통제에 따라 달라질 수 있다.

표 22 위협 시나리오별 종합 공격 실현 가능성

위협 ID	연결 공격 경로	종합 공격 실현 가능성
TS-01	AP-01, AP-03, AP-06, AP-09	높음
TS-02	AP-03, AP-05, AP-06, AP-10, AP-12	높음
TS-03	AP-07, AP-11	높음
TS-04	AP-01, AP-03, AP-06, AP-09	높음
TS-05	AP-03, AP-05, AP-06, AP-10, AP-12	높음

위협 ID	연결 공격 경로	종합 공격 실현 가능성
TS-06	AP-07, AP-11	높음
TS-07	AP-01, AP-03, AP-06, AP-09	높음
TS-08	AP-03, AP-05, AP-06, AP-10, AP-12	높음
TS-09	AP-07, AP-11	높음
TS-10	AP-01, AP-03, AP-06, AP-09	높음
TS-11	AP-03, AP-05, AP-06, AP-10, AP-12	높음
TS-12	AP-07, AP-11	높음
TS-13	AP-01, AP-03, AP-06, AP-09	높음
TS-14	AP-03, AP-05, AP-06, AP-10, AP-12	높음
TS-15	AP-07, AP-11	높음
TS-16	AP-01, AP-03, AP-06, AP-09	높음
TS-17	AP-03, AP-05, AP-06, AP-10, AP-12	높음
TS-18	AP-07, AP-11	높음
TS-19	AP-01, AP-03, AP-06, AP-09	높음
TS-20	AP-03, AP-05, AP-06, AP-10, AP-12	높음
TS-21	AP-07, AP-11	높음
TS-22	AP-02, AP-03, AP-10	높음
TS-23	AP-02, AP-03, AP-05, AP-10	높음
TS-24	AP-11, AP-12	높음
TS-25	AP-01, AP-02, AP-03	높음
TS-26	AP-02, AP-06, AP-12	높음
TS-27	AP-04	높음
TS-28	AP-12	매우 낮음
TS-29	AP-07, AP-12	높음
TS-30	AP-05, AP-06	높음
TS-31	AP-05, AP-06, AP-12	높음
TS-32	AP-05, AP-06, AP-12	높음
TS-33	AP-05, AP-07, AP-11	높음
TS-34	AP-16	매우 낮음
TS-35	AP-08, AP-09	중간
TS-36	AP-10	중간
TS-37	AP-11	높음

위협 ID	연결 공격 경로	종합 공격 실현 가능성
TS-38	AP-13	매우 낮음
TS-39	AP-13	매우 낮음
TS-40	AP-13	매우 낮음
TS-41	AP-14	중간
TS-42	AP-14	중간
TS-43	AP-15	높음

3.6 위험 값 결정(Risk Value Determination)

표 23 위험 값 결정 단계 목표

구분	내용
ISO/SAE 21434	15.8 Risk value determination
목적	위협 시나리오의 위험 값을 결정한다.
요구사항 및 권고사항	[RQ-15-15] 연결된 피해 시나리오의 영향과 공격 경로의 공격 실현 가능성으로 위험 값을 결정한다. [RQ-15-16] 위험 값은 1~5 이며 1 은 최소 위험이다.
작업 산출물	[WP-15-07] Risk values

표 24 위험 값 평가 기준

영향 등급	매우 낮음	낮음	중간	높음
심각한(Severe)	2	3	4	5
주요한(Major)	1	2	3	4
보통의(Moderate)	1	2	2	3
무시할 수 있는(Negligible)	1	1	1	1

표 25 위험 시나리오별 위험 값

위협	자산	피해 시나리오	AF	S/F/O/P 영향	R_S	R_F	R_O	R_P	최종 위험
TS-01	AS-01	DS-01	높음	N/Mo/Mo/N	1	3	3	1	3
TS-02	AS-01	DS-01	높음	N/Mo/Mo/N	1	3	3	1	3
TS-03	AS-01	DS-02	높음	N/N/Mo/N	1	1	3	1	3
TS-04	AS-02	DS-03, DS-04	높음	Ma/Mo/S/N	4	3	5	1	5
TS-05	AS-02	DS-03, DS-04	높음	Ma/Mo/S/N	4	3	5	1	5
TS-06	AS-02	DS-04	높음	Ma/Mo/S/N	4	3	5	1	5

위험	자산	피해 시나리오	AF	S/F/O/P 영향	R_S	R_F	R_O	R_P	최종 위험
TS-07	AS-03	DS-05, DS-06	높음	Mo/Mo/Mo/N	3	3	3	1	3
TS-08	AS-03	DS-05, DS-06	높음	Mo/Mo/Mo/N	3	3	3	1	3
TS-09	AS-03	DS-07	높음	N/N/Mo/N	1	1	3	1	3
TS-10	AS-04	DS-08	높음	N/Mo/Mo/N	1	3	3	1	3
TS-11	AS-04	DS-08	높음	N/Mo/Mo/N	1	3	3	1	3
TS-12	AS-04	DS-09	높음	N/N/Mo/N	1	1	3	1	3
TS-13	AS-05	DS-10, DS-11	높음	N/Mo/Ma/N	1	3	4	1	4
TS-14	AS-05	DS-10, DS-11	높음	N/Mo/Ma/N	1	3	4	1	4
TS-15	AS-05	DS-10	높음	N/Mo/Ma/N	1	3	4	1	4
TS-16	AS-06	DS-12	높음	N/N/Mo/N	1	1	3	1	3
TS-17	AS-06	DS-12	높음	N/N/Mo/N	1	1	3	1	3
TS-18	AS-06	DS-13	높음	N/N/Mo/N	1	1	3	1	3
TS-19	AS-07	DS-14, DS-15	높음	N/Mo/Mo/N	1	3	3	1	3
TS-20	AS-07	DS-14, DS-15	높음	N/Mo/Mo/N	1	3	3	1	3
TS-21	AS-07	DS-15	높음	N/N/Mo/N	1	1	3	1	3
TS-22	AS-08	DS-01~DS-15	높음	Ma/Mo/S/N	4	3	5	1	5
TS-23	AS-08	DS-01~DS-15	높음	Ma/Mo/S/N	4	3	5	1	5
TS-24	AS-08	DS-02, DS-04, DS-07, DS-09, DS-10, DS-13, DS-15	높음	Ma/Mo/S/N	4	3	5	1	5
TS-25	AS-09	DS-01, DS-03, DS-05, DS-06, DS-08, DS-10, DS-11, DS-12, DS-14, DS-15	높음	Ma/Mo/S/N	4	3	5	1	5
TS-26	AS-09	DS-01, DS-03, DS-05, DS-06, DS-08, DS-10, DS-11, DS-12, DS-14, DS-15	높음	Ma/Mo/S/N	4	3	5	1	5
TS-27	AS-09	DS-01, DS-03, DS-04, DS-05, DS-06, DS-08, DS-10, DS-11, DS-12, DS-14, DS-15	높음	Ma/Mo/S/N	4	3	5	1	5
TS-28	AS-09	DS-01~DS-15	매우 낮음	Ma/Mo/S/N	1	1	2	1	2
TS-29	AS-09	DS-02, DS-04, DS-07, DS-09, DS-10, DS-13, DS-15	높음	Ma/Mo/S/N	4	3	5	1	5
TS-30	AS-10	DS-17	높음	N/N/N/Mo	1	1	1	3	3
TS-31	AS-10	DS-16	높음	N/N/Mo/N	1	1	3	1	3
TS-32	AS-10	DS-16	높음	N/N/Mo/N	1	1	3	1	3
TS-33	AS-10	DS-16	높음	N/N/Mo/N	1	1	3	1	3
TS-34	AS-10	DS-16	매우 낮음	N/N/Mo/N	1	1	1	1	1
TS-35	AS-11	DS-01~DS-15	중간	Ma/Mo/S/N	3	2	4	1	4
TS-36	AS-11	DS-01~DS-15	중간	Ma/Mo/S/N	3	2	4	1	4
TS-37	AS-11	DS-02, DS-04, DS-07, DS-09, DS-10, DS-13, DS-15	높음	Ma/Mo/S/N	4	3	5	1	5

위험	자산	피해 시나리오	AF	S/F/O/P 영향	R_S	R_F	R_O	R_P	최종 위험
TS-38	AS-12	DS-01~DS-15	매우 낮음	Ma/Mo/S/N	1	1	2	1	2
TS-39	AS-12	DS-02, DS-04, DS-07, DS-09, DS-10, DS-13, DS-15	매우 낮음	Ma/Mo/S/N	1	1	2	1	2
TS-40	AS-12	DS-01~DS-15	매우 낮음	Ma/Mo/S/N	1	1	2	1	2
TS-41	AS-13	DS-01~DS-15	중간	Ma/Mo/S/N	3	2	4	1	4
TS-42	AS-13	DS-01~DS-15	중간	Ma/Mo/S/N	3	2	4	1	4
TS-43	AS-13	DS-02, DS-04, DS-07, DS-09, DS-10, DS-13, DS-15	높음	Ma/Mo/S/N	4	3	5	1	5

최종 위험 값은 국내 매뉴얼의 적용 예시와 동일하게 S/F/O/P 별 위험 값 중 가장 높은 값을 사용했다. 위험 하나에 여러 공격 경로가 연결된 경우에는 ISO/SAE 21434 15.8 의 예시와 같이 가장 높은 공격 실현 가능성을 종합값으로 사용했다.

3.7 위험 처리 결정(Risk Treatment Decision)

표 26 위험 처리 결정 단계 목표

구분	내용
ISO/SAE 21434	15.9 Risk treatment decision
목적	각 위험 시나리오에 적절한 위험 처리 옵션을 선택한다.
요구사항 및 권고사항	[RQ-15-17] 각 위험 시나리오의 위험 값을 고려해 위험 회피, 위험 감소, 위험 공유, 위험 유지 중 하나 이상을 결정한다.
작업 산출물	[WP-15-08] Risk treatment decisions

본 연구는 국내 TARA 매뉴얼의 예시 임계값을 reference Item 의 Risk Acceptance Criterion 으로 채택했다. Risk Value 가 2 이상이면 위험 감소, 1 이면 위험 유지로 결정한다. 이 임계값은 ISO/SAE 21434 가 규정한 보편적인 임계값이 아니라 본 분석에서 채택한 기준이다.

표 27 위험 처리 결과

위험	자산	위험 시나리오	위험 값	위험 처리 옵션	결정 근거
TS-01	AS-01	정당한 원격 접근제어 명령으로 위장한 명령이 처리되어 차량 접근제어 명령 데이터의 무결성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-02	AS-01	정상적인 잠금, 해제 명령의 동작 종류, 대상 또는 관련 제어정보가 변경되어 접근제어 명령 데이터의 무결성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-03	AS-01	차량 접근제어 원격명령이 차단, 손실, 처리 불가 상태가 되어 접근제어 기능의 가용성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-04	AS-02	원동기, 주행 관련 정당한 명령으로 위장한 명령이 처리되어 원동기, 주행 관련 명령 데이터의 무결성이 손상된다.	5	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-05	AS-02	원동기, 주행 명령의 종류 또는 파라미터가 변경되어 의도한 명령과 다른 동작이 수행될 수 있도록 무결성이 손상된다.	5	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-06	AS-02	원동기, 주행 관련 원격명령의 전달 또는 처리가 불가능해져 해당 원격 기능의 가용성이 손상된다.	5	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-07	AS-03	정당한 개구부 제어 명령으로 위장한 명령이 처리되어 창문, 선루프, 트렁크 등 개구부 명령의 무결성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-08	AS-03	개구부 명령의 방향, 대상 또는 파라미터가 변경되어 의도하지 않은 개폐 동작이 발생할 수 있도록 무결성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-09	AS-03	개구부 원격제어 명령이 차단 또는 처리되지 않아 정당한 사용자가 필요한 기능을 사용할 수 없게 된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.

위험	자산	위험 시나리오	위험 값	위험 처리 옵션	결정 근거
TS-10	AS-04	정당한 열, 공조 명령으로 위장한 명령이 처리되어 공조 및 편의 제어정보의 무결성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-11	AS-04	온도, 작동상태 또는 대상 편의기능 등의 명령 정보가 변경되어 사용자의 의도와 다른 열, 공조 동작이 발생한다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-12	AS-04	공조, 난방, 열선 등의 원격제어가 불가능해져 해당 편의기능의 사용성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-13	AS-05	정당한 충전, 고전압 배터리 관련 명령으로 위장한 명령이 처리되어 에너지 관리 명령의 무결성이 손상된다.	4	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-14	AS-05	충전 시작, 정지, 전류 또는 충전한도 등의 제어정보가 변경되어 사용자의 의도와 다른 충전 동작이 발생한다.	4	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-15	AS-05	원격 충전 제어가 차단 또는 처리 불가 상태가 되어 필요한 충전 기능을 사용할 수 없게 된다.	4	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-16	AS-06	정당한 경적, 등화, 차량찾기 명령으로 위장한 명령이 처리되어 신호 제어정보의 무결성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-17	AS-06	신호 종류, 대상 또는 동작정보가 변경되어 사용자의 의도와 다른 시각, 가청 신호가 발생한다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-18	AS-06	차량찾기 또는 신호 기능의 원격명령을 처리할 수 없어 해당 기능의 사용성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-19	AS-07	정당한 보안, 운용모드 명령으로 위장한 명령이 처리되어 해당 모드 제어정보의 무결성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-20	AS-07	보안 또는 제한 운용모드 활성화, 비활성 정보가 변경되어 의도하지 않은 모드 전환이 발생한다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-21	AS-07	보안 또는 제한 운용모드에 대한 정당한 원격제어가 불가능해져 해당 기능의 사용성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-22	AS-08	다른 차량 또는 기능을 정당한 명령 대상으로 위장하여 명령과 실제 대상 간 결합의 무결성이 손상된다.	5	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-23	AS-08	명령의 대상 차량, 대상 기능 또는 내부 라우팅 정보가 변경되어 의도하지 않은 대상에 명령이 적용된다.	5	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-24	AS-08	대상 식별 또는 내부 라우팅 정보를 사용할 수 없어 정당한 명령을 대상 기능에 전달하지 못한다.	5	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-25	AS-09	정당한 명령 발신자 또는 허용된 명령 처리 맥락으로 위장된 정보가 사용되어 차량측 명령 처리 판단의 무결성이 손상되고, 정상 조건이라면 수락되지 않아야 할 명령이 수락될 수 있다.	5	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-26	AS-09	요청 주체 또는 명령이 정상적으로 가지지 않아야 할 처리 권한을 획득하거나 수락 조건을 우회하여 차량측 명령 수락 판단의 무결성이 손상된다.	5	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-27	AS-09	과거에 정당했던 명령 또는 이미 처리된 명령이 현재의 새로운 명령처럼 다시 수락되어 현재 사용자 의도와 명령 처리 상태의 일치성이 깨진다.	5	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-28	AS-09	차량측 원격명령 처리조건, 판단상태 또는 처리 로직이 변경되어 수락되어야 할 명령이 거부되거나 거부되어야 할 명령이 수락된다.	2	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-29	AS-09	원격명령 수신, 해석 또는 수락 판단 기능이 자원고갈, 정지 또는 처리불능 상태가 되어 정당한 원격명령을 처리할 수 없게 된다.	5	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-30	AS-10	원격명령의 대상 차량, 명령 종류, 실행 결과 또는 관련 거래 메타데이터가 권한 없는 주체에게 노출되어 해당 정보의 기밀성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-31	AS-10	실제 차량 상태 또는 명령 처리 결과와 다른 상태정보가 정상 결과로 위장되어 사용자에게 제공됨으로써 결과정보의 무결성이 손상된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-32	AS-10	정상적으로 생성된 명령 처리 결과, 상태, 거래 메타데이터가 변경되어 실제 처리 결과와 보고 결과가 일치하지 않게 된다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-33	AS-10	처리 결과 또는 상태정보가 차단, 삭제, 전달 실패하여 사용자가 원격명령의 처리결과를 확인할 수 없다.	3	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-34	AS-10	원격명령의 발생, 처리, 실행에 대한 거래정보가 충분히 보존 또는 검증되지 않아 명령의 발생이나 처리 사실을 부인할 수 있게 되고, 명령 처리 이력의 신뢰성이 손상된다.	1	위험 유지	Risk 1 이며 현재 Attack Feasibility 와 영향 평가를 고려해 위험 유지. 향후 가정 또는 공격경로가 바뀌면 재평가.
TS-35	AS-11	차량 내부에서 정당한 원격명령 전달 데이터로 위장한 제어데이터가 대상 기능에 전달된다.	4	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.
TS-36	AS-11	차량 내부 전달 중 명령 종류, 대상 또는 파라미터 등이 변경되어 원래 수락된 명령과 다른 제어정보가 대상 기능에 전달된다.	4	위험 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위험 감소.

위협	자산	위협 시나리오	위협 값	위협 처리 옵션	결정 근거
TS-37	AS-11	수락된 원격명령의 차량 내부 전달이 차단되어 대상 기능이 정당한 명령을 수신하지 못한다.	5	위협 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위협 감소.
TS-38	AS-12	원격명령 대상 차량 기능을 구현하는 SW/FW 가 변조되어 정상 명령에 대해 의도하지 않은 차량 기능이 수행되거나 정상 기능이 변경된다.	2	위협 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위협 감소.
TS-39	AS-12	대상 기능 제어 SW/FW 또는 실행환경을 사용할 수 없게 되어 정당한 원격명령에 따른 차량 기능을 수행하지 못한다.	2	위협 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위협 감소.
TS-40	AS-12	대상 기능 제어기에서 허용되지 않은 높은 권한의 실행 또는 제어 권한을 획득하여 정상 원격명령 경로를 우회한 차량 기능 제어가 가능해진다.	2	위협 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위협 감소.
TS-41	AS-13	원격명령 판단에 사용되는 실제 차량 상태 또는 운용조건과 다른 허위 상태정보가 정상 입력으로 위장되어 판단 정보의 무결성이 손상된다.	4	위협 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위협 감소.
TS-42	AS-13	차량 상태정보가 생성 지점과 원격명령 처리 지점 사이에서 변경되어 실제 차량 상태와 다른 값이 명령 수락 판단에 사용된다.	4	위협 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위협 감소.
TS-43	AS-13	원격명령 수락 판단에 필요한 차량 상태, 운용조건 정보를 사용할 수 없게 되어 상태기반 판단 기능의 가용성이 손상된다.	5	위협 감소	국내 매뉴얼 예시 기준상 Risk 2 이상이므로 위협 감소.

3.8 CAL 및 사이버보안 목표, 주장

위험 감소로 처리한 위협에 대해서는 Cybersecurity Goal 을 정의한다. CAL 은 Risk Value 에서 직접 산출하지 않고, 국내 매뉴얼이 준용하는 ISO/SAE 21434 Annex E 의 예시처럼 최대 영향 등급과 대표 attack vector 를 기준으로 산정한다. 여러 위협을 하나의 Goal 로 묶은 경우 가장 높은 CAL 을 적용한다.

표 28 CAL 결정 기준

영향 등급	Physical	Local	Adjacent	Network
심각한(Severe)	CAL2	CAL3	CAL4	CAL4
주요한(Major)	CAL1	CAL2	CAL3	CAL4
보통의(Moderate)	CAL1	CAL1	CAL2	CAL3
무시할 수 있는(Negligible)	-	-	-	-

표 29 Cybersecurity Goal 별 CAL 평가

Goal	최대 영향	대표 Attack Vector	CAL
CSG-01	심각한(Severe)	네트워크(Network)	CAL4
CSG-02	심각한(Severe)	네트워크(Network)	CAL4
CSG-03	심각한(Severe)	네트워크(Network)	CAL4
CSG-04	심각한(Severe)	네트워크(Network)	CAL4
CSG-05	심각한(Severe)	국부적(Local)	CAL3
CSG-06	심각한(Severe)	국부적(Local)	CAL3
CSG-07	심각한(Severe)	국부적(Local)	CAL3

Goal	최대 영향	대표 Attack Vector	CAL
CSG-08	심각한(Severe)	국부적(Local)	CAL3
CSG-09	보통의(Moderate)	네트워크(Network)	CAL3
CSG-10	보통의(Moderate)	네트워크(Network)	CAL3

표 30 사이버보안 목표 단계 목표

구분	내용
ISO/SAE 21434	9.4 Cybersecurity goals
목적	Cybersecurity Goal 과 Cybersecurity Claim 을 규정한다.
요구사항 및 권고사항	[RQ-09-05] 위험 감소 대상 위협에 대해 하나 이상의 Cybersecurity Goal 을 정의한다. [RQ-09-06] 위험 공유 또는 분석 가정으로 인해 위험을 유지하는 경우 Cybersecurity Claim 을 정의한다. [RQ-09-07] TARA, 위험 처리, Goal/Claim 의 완전성, 정확성, 일관성을 검증한다.
작업 산출물	[WP-09-03] Cybersecurity goals [WP-09-04] Cybersecurity claims [WP-09-05] Verification report for cybersecurity goals

표 31 사이버보안 목표

Goal ID	관련 자산	관련 위협	최대 위험	위험 처리	CAL	사이버보안 목표
CSG-01	AS-01, AS-02, AS-03, AS-04, AS-05, AS-06, AS-07, AS-09	TS-01, TS-04, TS-07, TS-10, TS-13, TS-16, TS-19, TS-25, TS-26	5	위험 감소	CAL4	정당한 권한을 가진 주체가 허용된 차량 기능에 요청한 원격명령만 차량에서 수락하고 실행해야 한다.
CSG-02	AS-01~AS-08	TS-02, TS-05, TS-08, TS-11, TS-14, TS-17, TS-20, TS-22, TS-23	5	위험 감소	CAL4	원격명령의 종류, 파라미터, 대상 차량, 대상 기능 및 라우팅 정보는 생성된 시점부터 차량 내 최종 전달까지 허가 없이 변경되어서는 안 된다.
CSG-03	AS-09	TS-27	5	위험 감소	CAL4	원격명령은 허용된 유효기간과 처리 횟수 내에서만 실행되어야 하며, 이미 처리했거나 유효기간이 지난 명령이 새로운 명령으로 다시 실행되어서는 안 된다.
CSG-04	AS-01~AS-09, AS-11	TS-03, TS-06, TS-09, TS-12, TS-15, TS-18, TS-21, TS-24, TS-29, TS-37	5	위험 감소	CAL4	원격명령의 수신, 처리, 대상 식별, 내부 전달 기능은 비정상적인 요청이나 통신 부하가 발생하더라도 정상 명령 처리를 지속하거나 안전한 상태로 실행해야 한다.
CSG-05	AS-13	TS-41, TS-42, TS-43	5	위험 감소	CAL3	원격명령 수락 판단에 사용하는 차량 상태와 운용조건 정보는 실제 차량 상태와 일치하도록 보호되어야 하며, 필요한 상태정보를 신뢰할 수 없거나 사용할 수 없는 경우 부적절한 명령을 수락해서는 안 된다.
CSG-06	AS-09	TS-28	2	위험 감소	CAL3	차량측 원격명령 수신, 해석 및 수락 판단에 사용되는 처리 로직과 관련 상태 및 설정은 비인가 변경으로부터 보호되어야 한다.
CSG-07	AS-11	TS-35, TS-36	4	위험 감소	CAL3	차량측 원격명령 처리부에서 대상 기능 제어기까지 전달되는 내부 제어정보는 정당한 송신원에서 생성된 정보임을 확인할 수 있어야 하며 전송 과정에서 변조되어서는 안 된다.

Goal ID	관련 자산	관련 위협	최대 위험	위험 처리	CAL	사이버보안 목표
CSG-08	AS-12	TS-38, TS-39, TS-40	2	위험 감소	CAL3	원격명령 대상 기능을 수행하는 차량 제어기의 소프트웨어, 펌웨어 및 실행 권한은 비인가 변경, 비인가 실행 및 서비스 중단으로부터 보호되어야 한다.
CSG-09	AS-10	TS-31, TS-32, TS-33	3	위험 감소	CAL3	원격명령의 처리 결과와 차량 상태정보는 실제 실행 결과와 일치하도록 보호되고 정당한 사용자에게 필요한 시점에 제공되어야 한다.
CSG-10	AS-10	TS-30	3	위험 감소	CAL3	원격명령의 대상 차량, 명령 종류, 처리 시간 및 결과 등 차량 이용 행태를 나타낼 수 있는 거래정보는 권한 없는 주체에게 노출되어서는 안 된다.

표 32 사이버보안 주장

Claim ID	자산	위협	위험 값	위험 처리	CAL	사이버보안 주장
CSC-01	AS-10	TS-34	1	위험 유지	해당 없음(Claim)	원격명령의 발생 및 실행 이력에 대한 부인 위험은 현재 Reference Item 에서 Risk 1 로 평가되어 유지한다. 이 판단은 해당 이력을 번조하려면 차량측의 높은 실행권한, 내부 구현정보 및 전문적인 공격수단이 필요하다는 가정에 근거한다. 향후 이 가정이 성립하지 않거나 새로운 공격경로가 확인되면 공격 실현 가능성과 위험 처리 결정을 다시 평가한다.

본 문서는 CAL 을 Cybersecurity Goal 의 보증 수준으로 관리한다. Cybersecurity Claim 자체에는 CAL 을 필수 속성으로 부여하지 않아 “해당 없음(Claim)”으로 표기했다.

3.9 TARA 및 Goal/Claim 추적성 검증

표 33 추적성 및 일관성 검증

검증 항목	결과	확인 내용
Item Definition 대비 TARA 범위	PASS	7 개 Item Function 이 Asset/Damage 에 연결됨
Asset/Damage 대비 Threat 완전성	PASS	13 Assets, 17 Damage Scenarios, 43 Threat Scenarios 를 추적 가능
Threat 대비 Attack Path	PASS	43/43 Threat Scenario 가 하나 이상의 Attack Path 에 연결됨
Attack Path Feasibility	PASS	16/16 Attack Path 평가 완료
Threat Risk Value	PASS	43/43 Risk Value 산정 완료
Risk Treatment	PASS	43/43 Treatment 결정 완료
Reduce Threat 대비 Goal	PASS	42/42 위험 감소 위협이 CSG-01~CSG-10 에 연결됨
Retain Threat 대비 Claim	PASS	TS-34 가 CSC-01 에 연결됨
Goal/Claim 상호 일관성	PASS	Authorization, Integrity, Freshness, Availability, Vehicle State, SW/FW, Result, Privacy 보호 목적 사이에 직접 충돌 없음

4. 최종 정리

본 Reference Item 에 대한 ISO/SAE 21434 Clause 15 TARA 는 WP-15-01 부터 WP-15-08 까지 모두 작성했다. 분석 결과는 13 개 자산, 17 개 피해 시나리오, 43 개 위협 시나리오, 16 개 공격 경로로 구성되며, 모든 영향 등급, 공격 실현 가능성, 위험 값과 위험 처리 결정에 값이 존재한다. Risk Value 2 이상을 위험 감소로 처리하는 국내 매뉴얼의 예시 기준을 적용한 결과 42 개 위협은 위험 감소, TS-34 1 개는 위험 유지로 결정했다.

이어서 42 개 위험 감소 위협을 10 개의 Cybersecurity Goal 로 통합했고, 가정에 의존하는 위험 유지 건에는 Cybersecurity Claim 을 작성했다. 이 단계까지가 TARA 결과를 Concept 단계의 Goal/Claim 으로 연결한 범위다. 이후 Clause 10 Product Development 의 구체 설계, 구현, 통합시험 결과는 본 TARA 정리본의 범위에 포함하지 않는다. 다음 절에서는 이 TARA 에서 Risk 5 및 CAL4 로 식별된 원격명령 핵심 위협을 대상으로, 기존에 수행한 Z3, ProVerif, Tamarin 정형분석 결과를 현재 TARA 식별자와 다시 연결하여 제시한다.

5. 정형 분석(Formal Analysis)

본 절에서는 TARA 전체를 수리적으로 증명했다고 주장하지 않는다. 현재 TARA 에서 위험 값 5, 위험 처리 "감소", CAL4 로 분류된 원격명령 핵심 위험 가운데 명령 발급·권한 검증, 대상 및 명령 의미의 결합, 재전송 방지와 직접 대응되는 보안 속성을 정형화하고, 기존에 수행한 Z3, ProVerif, Tamarin 분석 결과를 현재 TARA 의 Threat-Goal 구조에 재매핑하였다.

5.1 분석 대상 선정

정형분석 대상은 임의로 고르지 않았다. 공통 원격명령 처리경로를 공격하며 최종 위험 값이 5 이고 CAL4 Goal 에 연결되는 위협을 우선 대상으로 삼았다. 이에 따라 TS-22 대상 차량·기능 스푸핑, TS-23 대상·라우팅 변조, TS-25 정당한 처리문맥 스푸핑, TS-26 수락·권한 검증 우회, TS-27 재전송·오래된 명령·중복 수락을 정형분석의 핵심 범위로 두었다. 정상 명령이 보안기능 도입 뒤에도 처리될 수 있는지는 별도의 정상 도달성 속성 P0 으로 확인했다.

표 34 TARA 기반 정형분석 대상

TARA 위험	위험 값	연결 Goal	CAL	정형분석 초점
TS-22 대상 차량·기능 스푸핑	5	CSG-02	CAL4	인증된 명령의 대상 차량·기능 결합
TS-23 대상·라우팅 변조	5	CSG-02	CAL4	대상·동작·파라미터·명령 식별자의 의미 보존
TS-25 정당한 처리문맥 스푸핑	5	CSG-01	CAL4	수락 이전의 정상 발급 및 권한 정책 대응
TS-26 수락·권한 검증 우회	5	CSG-01	CAL4	권한 없는 명령의 수락 가능성
TS-27 재전송·오래된 명령·중복 수락	5	CSG-03	CAL4	동일 명령의 중복 수락과 상태 지속성

5.2 정형 보안 속성

정형모델은 원격명령의 정상성, 권한 대응, 경계 의미 보존, 중복 수락 제한을 P0 부터 P3 까지 네 속성으로 구분한다. P0 은 보안통제가 정상 기능까지 막는지를 확인하는 존재성 속성이고, P1~P3 은 공격자가 임의로 위반할 수 없어야 하는 보안 속성이다.

표 35 정형 보안 속성 정의

속성	정의	현재 TARA 와의 대응	주요 도구
P0 정상 도달성	정상 명령 1 건과 서로 다른 cid 를 가진 정상 명령 2 건이 수락되는 실행이 존재해야 한다.	보안통제 적용 후 정상 기능 보존 확인	Tamarin, Z3
P1 발급·정책 대응	모든 수락에는 그보다 앞선 동일 내용의 Issue 와 AuthorizedAtIssue 가 존재해야 한다.	TS-25, TS-26 / CSG-01	Tamarin, ProVerif, Z3
P2 경계 의미 보존	최종 수신 대상, 동작, 파라미터, cid 가 인증된 상위 명령의 값과 동일해야 한다.	TS-22, TS-23 / CSG-02	Tamarin, ProVerif 변형, Z3
P3 중복 수락 제한	동일한 (issuer, VIN, cid)의 명령은 최대 한 번만 수락되어야 한다.	TS-27 / CSG-03	Tamarin, ProVerif, Z3

P1: $\text{Accept}(c) \Rightarrow \text{Earlier}(\text{Issue}(c)) \wedge \text{AuthorizedAtIssue}(c)$

P2: $\text{Accept}(c) \Rightarrow \text{ReceivedFields}(c) = \text{AuthenticatedIssuedFields}(c)$

$$P3: \text{Accept}(i, v, \text{cid})@t_1 \wedge \text{Accept}(i, v, \text{cid})@t_2 \Rightarrow t_1 = t_2$$

5.3 분석 도구와 역할

세 도구는 같은 속성을 반복 확인하기 위한 용도가 아니라 서로 다른 분석 질문을 담당한다. Z3 는 유한 전이모델에서 반례의 존재 여부와 별도의 귀납 의무를 확인했고, ProVerif 는 Dolev-Yao 공격자 모델에서 명령 발급과 수락의 **correspondence** 및 인증 필드 결합을 분석했다. Tamarin 은 명령 소비상태가 시간에 따라 변하는 상황을 다루어 **replay**, 비원자 처리, 재시작 시 상태 보존을 분석했다.

표 36 정형분석 도구별 역할과 실행 환경

도구	버전	분석 역할	결과 해석
Z3	4.16.0	경계 전이모델의 SAT 반례 탐색, 수정 설계의 bounded 탐색, 상태 불변식 귀납 의무 확인	SAT 는 반례 또는 정상 witness 의 존재를 뜻한다. BOUNDED_UNSAT 는 지정한 depth 내 반례가 없다는 의미이며 완전증명이 아니다.
ProVerif	2.05	Issue→Accept correspondence, 인증 대상 필드의 결합 여부, injective correspondence 분석	일반 correspondence true 와 injective false 를 구분해 해석한다.
Tamarin	1.12.0	상태를 갖는 원격명령 프로토콜의 시간적 속성, replay, 원자성, 재시작 상태 보존 분석	verified, falsified, unknown 을 구분하고 반례 trace 가 있는 경우 그 실행순서를 근거로 사용한다.

5.4 Z3 분석 결과

Z3 분석에서는 취약 설계 변형과 대응을 적용한 fixed 설계를 분리했다. 사례 A 는 상위 명령과 하위 명령 사이의 경계 결합이 약한 경우, 사례 B 는 검사와 소비 기록이 원자적으로 처리되지 않는 경우, 사례 C 는 상위·하위 재전달 범위가 일치하지 않는 경우를 나타낸다. 취약 설계에서는 실제 SAT 반례가 확인됐고, fixed 설계에서는 지정된 탐색 깊이 안에서 반례가 관찰되지 않았다. 따라서 fixed 설계의 bounded 결과는 증명이 아니라 제한된 범위의 반례 부재로 기술한다.

표 37 Z3 주요 결과

분석 항목	결과	해석
사례 A: perhop P1/P2	SAT, 최초 depth 4	발급·정책 대응 또는 경계 의미 보존을 위반하는 실행 존재
사례 A: fixed P1/P2	BOUNDED_UNSAT, depth 0~8	지정 범위에서 반례 없음. 완전증명으로 해석하지 않음
사례 B: 비원자 P3	SAT, 최초 depth 7	두 CHECK 가 두 COMMIT 보다 먼저 진행되어 동일 명령 중복 수락 가능
사례 B: fixed P3	BOUNDED_UNSAT, depth 0~10	지정 범위에서 중복 수락 반례 없음
사례 C: perhop P3	SAT, 최초 depth 7	상위 소비 범위 불일치로 중복 수락 가능
사례 C: fixed P3	BOUNDED_UNSAT, depth 0~10	지정 범위에서 반례 없음
정상 경로 P0: fixed	SAT, depth 8	보안대응 적용 뒤에도 서로 다른 정상 명령 2 건의 수락 경로 존재
귀납 의무 4 개	부정식 UNSAT, PROVED	초기 불변식, freshness guard, 원자적 수락, 상태 보존 재시작에 대한 귀납 의무 성립
저장소 손실 witness	SAT	상태가 이전 값으로 되돌아가면 같은 cid 가 다시 수락되는 반례 재현

5.5 ProVerif 분석 결과

ProVerif에서는 명령이 정상적으로 발급된 사건과 차량측 수락 사건의 **correspondence**를 중심으로 분석했다. 전체 필드를 인증한 모델에서는 일반 **correspondence**가 성립했으나 **injective correspondence**는 성립하지 않았다. 이는 발급된 명령과 수락된 명령의 내용 대응만으로는 동일 명령의 중복 수락까지 막을 수 없음을 뜻한다. 또한 **issuer, subject, VIN, operation, parameters, cid** 중 하나를 인증 범위에서 제외한 변형에서는 일반 **correspondence**가 모두 실패했다. 따라서 TS-22, TS-23, TS-25, TS-26에 대응하는 명령 문맥은 개별 필드가 아니라 하나의 인증된 의미 단위로 결합되어야 한다.

표 38 ProVerif 주요 결과

모델	일반 correspondence	Injective	해석
fields_D1 (bearer 만)	false	false	bearer 정보만으로는 발급·수락 대응을 보장하지 못함
fields_D2 (전체 필드 인증)	true	false	명령 내용 대응은 성립하지만 중복 수락까지 배제하지 못함
fields_D3 (전체 필드 인증 + 비원자 소비)	true	false	내용 대응과 replay-safe 소비는 별개의 속성임
issuer/subject/VIN/operation/params/cid 각각 누락	전부 false	false	핵심 명령 문맥 중 하나라도 인증 범위에서 빠지면 correspondence가 깨짐
VIN 미인증 + VIN 별 검증키(v2)	true	false	VIN 별 키 선택 자체가 binding 역할을 할 수 있으나 injective replay 성질은 별도 필요

5.6 Tamarin 분석 결과

Tamarin 분석은 P3와 직접 연결되는 상태 변화에 초점을 맞췄다. 상태 투영 모델과 지속상태 투영 모델에서는 같은 (**issuer, VIN, cid**)의 중복 수락 제한이 성립했다. 반면 검사와 기록을 분리한 비원자 모델에서는 13전이 반례가, 재시작 시 수신측 상태가 손실되는 모델에서는 15전이 반례가 확인됐다. 따라서 replay방지는 단순히 cid를 메시지에 넣는 것만으로 충분하지 않고, 검사와 소비 기록의 원자성 및 재시작 이후 상태 지속성이 함께 보장되어야 한다.

표 39 Tamarin 주요 결과

모델/속성	결과	해석
전체 모델 P0, P1, P2	VERIFIED	정상 도달성, 발급·정책 대응, 경계 의미 보존이 해당 모델에서 성립
상태 투영 P3	VERIFIED, P3 3 steps / helper 145 steps	상태 재사용 방지 보조정리와 함께 중복 수락 제한 성립
지속상태 투영 P3	VERIFIED, P3 3 steps / helper 649 steps	수신측 상태가 지속되는 재시작 구조에서 중복 수락 제한 성립
비원자 모델 P3	FALSIFIED, 13-step trace	두 처리자가 같은 상태를 확인한 뒤 각각 수락하는 race 반례
저장소 손실 모델 P3	FALSIFIED, 15-step trace	수락 후 상태가 이전 값으로 복원되면 동일 cid 재수락 가능
전체 원본 모델의 직접 P3	UNKNOWN	2 GiB heap 한도에서 탐색 종료. 이 항목은 증명 또는 반증으로 처리하지 않음
계측본의 P3	VERIFIED, 5 steps	적절한 보조정리와 계측 action을 사용한 모델에서는 P3가 성립

5.7 TARA와 정형분석의 추적성

정형분석의 결과는 TARA의 위험 값을 다시 계산하기 위한 입력이 아니라, 위험 감소로 결정한 핵심 명령보안 Goal이 논리적으로 어떤 조건에서 성립하거나 깨지는지 확인하는 검증 증거로 사용한다. 특히 P1은 CSG-01의 권한 검증, P2는 CSG-02의 대상·명령 의미 결합, P3는 CSG-03의 freshness 및 replay방지와 대응된다.

표 40 TARA-정형분석 추적성

TARA 위협	Goal	정형 속성	주요 근거	판정
TS-25, TS-26	CSG-01	P1 발급·정책 대응	Tamarin P1 VERIFIED, ProVerif 전체 필드 모델 일반 correspondence true, Z3 취약 변형 SAT	핵심 속성 분석 완료
TS-22, TS-23	CSG-02	P2 경계 의미 보존	Tamarin P2 VERIFIED, ProVerif 필드 누락 변형 전부 false, Z3 사례 A 반례	핵심 속성 분석 완료
TS-27	CSG-03	P3 중복 수락 제한	Tamarin 상태/지속 투영 VERIFIED, 비원자·저장소 손실 FALSIFIED, Z3 race/loss 반례	조건부 성립 및 실패조건 확인
정상 기능 보존	CSG-01~03 공통	P0 정상 도달성	Tamarin 정상 trace VERIFIED, Z3 fixed 정상 witness SAT depth 8	보안대응 후 정상 경로 확인

6. 차량 상태 판단의 보강 분석

본 장은 기존 P0~P3 를 대체하지 않고, 앞서 정의한 TS-41~TS-43 과 CSG-05 에 대응하는 상태 입력 검증을 추가한다. 분석 대상은 연구용 수신자가 명령 수락을 기록하기 직전의 판단이다. 실제 ECU, 차량 센서, CAN 송신 또는 액추에이터의 물리 동작을 시험한 결과가 아니다. 원래 TARA 의 위협 식별자, 영향 등급, 공격 실현 가능성, 위험 값과 CAL 은 변경하지 않았다. 새 검증 결과가 그 평가값 자체의 정확성을 입증하는 것은 아니다.

기존 정형분석과 구현 실험은 2026 년 9 월 21 일 보고서에 기록된 결과다. 이번 보강 분석과 로컬 시험은 별도 코드로 수행했다. 본 장 이후에는 기존 보고서에서 인용한 결과, 이번에 실행한 결과, 아직 검증되지 않은 항목을 구분한다. 원문의 4 장과 5.8 절에 적힌 분석 범위는 해당 시점의 범위이며, 이번 추가 범위는 6~8 장에서 명시한다. [E1, E2, E3]

표 41. 이번 통합에서 명확히 한 해석과 출처

항목	정확한 적용 범위
기존 P1	발급 시점의 독립 정책과 수락의 대응이다. 현재 시점의 권한 회수, 로그인 보안, 인간 사용자의 의도까지 검증한 것은 아니다.
기존 P3	동일 (issuer, VIN, cid)의 중복 수락 제한이다. 명령의 절대시간 만료, 물리 실행 횟수 또는 exactly-once 효과의 증명이 아니다.
기존 Tamarin P3	원본 전체 모델 직접 질의의 UNKNOWN, 상태 투영 모델의 증명, 계측본의 보조정리 기반 증명을 구분한다. 원본으로의 이전 논증은 기계화되지 않았다.
기존 분석의 선정 경위	기 수행한 정형분석 결과를 새 TARA 의 위협과 목표에 사후 연결한 것이다. 새 위험 순위에 따라 처음부터 모든 모델을 구축한 것으로 해석하지 않는다.
소스 확보 방식	Library 에서 receiver.py, pipeline.py, protocol.py 의 추출 텍스트를 확보했다. 원본 바이트 확보는 실패했으므로 2026-09-21 저장소와의 바이트 동일성은 확인하지 못했다.
이번 시험의 원본 보존	추출 텍스트 사본 3 개는 시험 전후 SHA-256 이 일치했다. 이 확인을 원 저장소의 무수정 또는 원본 해시 일치로 확대하지 않는다.
기존 문서의 PASS	표의 항목 연결 또는 특정 모델의 결과를 뜻한다. TARA 전체의 규범적 적합성이나 차량 전체의 보안 달성을 뜻하지 않는다.

6.1 검증 요구와 실험 정책

아래 V 식별자는 이번 통합에서 증거를 추적하기 위해 부여한 검증 항목이다. ISO 의 요구사항 식별자가 아니며, 앞서 제안한 CR 요구사항을 대체하지 않는다. V-01~V-04 는 기존 분석의 실제 범위를 정리했고 V-05 와 V-06 은 CSG-05 에서 새로 구체화했다.

표 42. 검증 항목과 TARA 의 연결

항목	요구와 판정 기준	TARA 연결
V-01	수락된 명령은 동일 내용의 앞선 발급 및 발급 시점 권한 정책에 대응해야 한다.	TS-25, TS-26 / CSG-01
V-02	인증된 명령의 대상, 동작, 매개변수, 식별자가 최종 수신 명령과 일치해야 한다.	TS-22, TS-23 / CSG-02
V-03	같은 (issuer, VIN, cid)의 수락 기록은 중복 생성되지 않아야 한다.	TS-27 / CSG-03
V-04	중복 판단 상태를 보존한 재개방 또는 정의된 재시작에서 이전 명령을 다시 수락하지 않아야 한다.	TS-27 / CSG-03
V-05	수락에 사용되는 상태 표본의 출처, 인증값, 대상 차량, 일관성 및 표본 시각을 확인해야 한다.	TS-41~TS-43 / CSG-05
V-06	사전 검사 이후 상태나 정책이 바뀌면 이전 검사 결과만으로 수락하지 않고 수락 직전에 다시 확인해야 한다.	TS-41~TS-43 / CSG-05

실험 정책 R-STATE-01 은 속도 값 0 과 기어 P 일 때만 선택된 합성 명령을 허용한다. 상태 표본의 허용 나이는 0~100 ms 로 두었다. 이는 상태 검사의 동작을 관찰하기 위한 연구용 조건이다. 모든 차량의 도어 잠금이나 원격 명령이 이 조건을 따라야 한다는 뜻이 아니며, 100 ms 역시 ISO 나 OEM 이 규정한 값이 아니다. 기존 구현의 lock/unlock 동작을 그대로 사용하므로 원동기, 충전 또는 모든 70 개 명령을 시험한 것으로 집계하지 않는다. [E3, N1, N2]

6.2 상태와 전이의 모델

단순히 Accept 를 Allowed 의 별칭으로 정의한 뒤 같은 식을 증명하지 않았다. 모델은 상태 표본을 만든 시점과 수락 판단 시점의 실제 상태, 수신한 보고값을 서로 다른 변수로 둔다. 보고값이 정책을 만족하는 것과 수락 시점의 실제 상태가 정책을 만족하는 것을 별도로 계산한다. 이 둘을 연결하는 조건은 다음 세 가정이다.

표 43. 신규 상태 모델의 명시적 가정

가정	내용	보장하지 않는 것
A-STATE-01	정직한 제공자가 올바른 출처, 인증값, 일관성 표시와 차량 식별자를 가진 표본을 생성하면, 보고값은 표본 시점의 상태와 같다.	센서 오류, 침해된 제공자의 거짓 보고를 암호 인증만으로 판별하지 않는다.
A-STATE-02	정책에 영향을 주는 상태가 바뀔 때 신뢰되는 상태 제공자가 세대 또는 상태 버전을 변경한다. 두 값이 모두 같으면 해당 상태가 유지된 것으로 모델링한다.	실차 상태 변화가 누락되거나 버전 관리자가 침해된 경우를 보장하지 않는다.
A-STATE-03	정책이 바뀌면 정책 버전이 달라진다. 같은 정책 버전은 같은 임계값을 나타낸다.	설정 저장소의 무결성이나 배포 체계의 안전성을 별도로 증명하지 않는다.

상태 표본에는 출처, 차량 식별자, 속도, 기어, 표본 시각, 제공자 세대, 상태 버전, 일관성 표시가 포함된다. 수락 조건은 명령 검사 성공, 상태 존재, 출처 확인, 인증값 일치, 일관성, 시간 범위, 차량 결합, 세대 일치, 상태 버전 일치, 정책 버전 일치 및 보고값의 정책 충족으로 구성한다. 명령 검사 성공은 기존 P1/P2 영역을 추상화한 입력이며, 새 상태 질의에서 그 암호학적 안전성을 재증명하지 않았다.

P4-STATE 의 핵심 질문: 수락 조건을 통과했으나 수락 시점 상태가 정책을 만족하지 않는 해가 존재하는가?

질의: $\text{Model} \wedge \text{ReceiverAccept}(c) \wedge \neg \text{AllowedNow}(c, \text{actual_state})$

UNSAT 는 명시한 가정과 두 시점 상태 관계 안에서 위반 해가 없다는 뜻이다. 임의 길이의 실행 전체나 실차 물리 안전의 증명으로 확대하지 않는다. 상태 누락, 충돌 표시, 시각 오류에 대한 질의는 해당 불량 입력이 수락되는지 별도로 검사했다. [N1, D1]

6.3 Z3 실행 결과

기존 분석의 Z3 버전과 구분하기 위해 이번 환경을 별도 기록했다. 이번에는 설치되어 있던 libz3.so.4 의 C API 를 사용했고 실제 확인된 버전은 4.13.3.0 이다. 15 개 SMT-LIB 질의를 각각 3 회 실행했다. 고유 질의의 결과는 SAT 10 개, UNSAT 5 개였으며 판정 불능은 없었다. 45 회 실행 모두 같은 질의의 기대 결과와 일치했다. SAT 값은 별도의 Python 계산으로 가드, 상태 관계 가정 및 질의 목적과의 일치를 확인했다. 실행 시간과 원시 결과는 results/smt 에 저장했다. [N1]

표 44. 차량 상태 보장 분석의 고유 질의 15 개

질의	분석 조건	결과	해석
SZ-01	완전 검사와 정직한 상태 제공자	UNSAT	가정이 유지되는 완전 검사에서 수락 시점 정책 위반 해 없음
SZ-02	정상 수락의 존재성	SAT	정상 수락이 가능한 해 존재. 보안 반례가 아님
SZ-03	출처 검사 제거	SAT	출처 검사를 제거한 변형에서 잘못된 상태 보고의 수락 가능
SZ-04	무결성 검사 제거	SAT	인증값 검사를 제거한 변형에서 잘못된 상태 보고의 수락 가능
SZ-05	상태 누락 시 허용하는 비교 설계	SAT	상태가 없을 때 허용하면 정책 위반 수락 가능
SZ-06	상태정보 시간 검사 제거	SAT	오래된 표본의 수락 가능. 시간 품질 조건 위반이며 물리 위해 자체를 뜻하지 않음
SZ-07	검사 이후 상태 변경, 버전 재검사 없음	SAT	이전 보고값은 허용되지만 현재 상태는 허용되지 않는 수락 가능
SZ-08	완전 검사에서 상태 누락	UNSAT	상태가 없는 입력의 수락 해 없음
SZ-09	완전 검사에서 상충 상태	UNSAT	상충한 것으로 표시된 입력의 수락 해 없음
SZ-10	상태정보의 대상 차량 결합 제거	SAT	다른 차량의 허용 상태를 이용한 수락 가능
SZ-11	재시작 세대 검사 제거	SAT	재시작 이후 이전 세대 표본을 수락하는 해 존재

질의	분석 조건	결과	해석
SZ-12	검사 이후 정책 변경, 정책 버전 검사 없음	SAT	이전 정책으로는 허용되지만 현재 정책으로는 금지된 수락 가능
SZ-13	정상 인증을 사용하는 상태 제공자 자체의 거짓 보고	SAT	제공자가 거짓 보고하면 완전한 메타데이터 검사만으로 실제 상태를 보장할 수 없음
SZ-14	완전 검사에서 상태 버전 불일치	UNSAT	상태 버전 불일치 입력의 수락 해 없음
SZ-15	완전 검사에서 미래 시각	UNSAT	미래 시각 표본의 수락 해 없음

SZ-13 은 제거해야 할 불편한 결과가 아니라, 주장 범위를 결정하는 결과다. 명령과 상태 메시지에 올바른 인증값이 있어도 상태 제공자 자체가 거짓 값을 만들 수 있다면 실제 차량 상태와의 일치하는 보장되지 않는다. 따라서 CSG-05 의 전체 달성을 선언하지 않고, 출처 및 전달 무결성이 유지되고 상태 제공자가 정직하다는 조건 아래 수락 판단을 검증한 것으로 기록한다.

SZ-07 과 SZ-12 는 사전 검사의 결과를 계속 사용하는 설계의 문제를 보여준다. 상태 버전 또는 정책 버전이 바뀐 경우 최종 수락 지점에서 재확인해야 한다. 다만 이번 모델은 두 시점의 관계를 분석하므로 센서 통신 지연, 연속적인 차량 운동, 실시간 스케줄링 및 실행 중 상태 변화를 직접 모델링하지 않았다.

6.4 상태 검사 모듈과 기존 수신기의 연결

새 `state_gate.py` 는 기존 `receiver.py`, `pipeline.py`, `protocol.py` 를 변경하지 않고 `pipeline.Receiver.receive` 앞에 배치했다. `prepare` 에서 상태 표본과 명령 바이트의 해시를 묶고, `commit` 에서 명령 연결과 정책 버전, 상태 품질을 다시 확인한 뒤 기존 수신기를 호출한다. 재검사에 실패하면 기존 수신 저장소를 호출하지 않는다. 상태 거부 후 같은 미소비 명령을 정상 상태에서 다시 전달할 수 있는지도 시험했다. [N2]

연구용 상태 제공자는 상태 표본에 HMAC-SHA256 을 붙이고, 상태 변화에 따라 버전을 올린다. 이는 이번에 추가한 구현 선택이지 기존 CC-TRACE 에 이미 있었다는 주장이 아니다. 상태 갱신과 수신 호출은 같은 프로세스의 `StateAuthority` 잠금을 이용해 직렬화했다. 이 잠금은 해당 객체를 사용하는 쓰기만 조정하며, 실차 센서나 다른 프로세스의 상태 변화, 물리 동작을 원자적으로 묶지 못한다.

표본 시각은 시험에서 공급한 논리 시각이다. 표본 나이를 확인한 시점부터 SQLite 수락 기록이 커밋되는 시점까지의 실시간 지연 상한은 검증하지 않았다. 실제 시스템으로 옮기려면 상태 갱신 계약과 최종 실행 지점의 재검사, 시간 오차 및 지연 허용치를 제품 사양으로 정해야 한다.